

High Level Design - Contact Center Re-Platform - MVP (PCI)

Created by Robert Ascan - EXT, last modified yesterday at 7:25 PM

Purpose of HLD

The High Level Design Document (HLD) is the single solution document created during a project. It contains solution summary, architectural information and solution details that are used as an input for development and testing activities.

How to Complete this Document

- The BSA (or Solution Delivery Manager in the case where the project is without a BSA) is responsible for collating information and populating Business Section (Section 1) of this document
- The Solution Architect (SA), with input from the Infra Solution Architect, ICSU and the Enterprise Architect is responsible for completing the Architecture Section (Section 2) of this document
- After the completion of Sections 1 and 2, the SA is responsible for submitting the HLD to the DA for approval
- Sequel to DA approval, the BSA (Solution Delivery Manager in the case where the project is without a BSA) is responsible for coordinating and consolidating inputs from requisite Tech teams to complete the Technical Section (Section 3) of this document and obtaining sign-offs as required.
- This document must be submitted technical and business stakeholder approvals via Jira workflow, leveraging a Jira HLD ticket (see [How to Create an HLD Artifact ticket](#) for details).
- It is recommended that this document (HLD) be hosted as a shared document on the Project website so updates can be made simultaneously by participating stakeholders

Project ID	CMC24-115	Project Delivery Owner	Sougat Ray
Project Name	RBCCR - Contact center replatform project	IT Project Manager	Ramesh Krishna
Package Number		Business Owner	Olya Sanakoev
Package Name		Engagement Manager	Rachel Pyo
		Solution Architect	Robert Ascan / Abhishek Suman
		Product owner / Business System Analyst	Neil Campbell / Suyash Vij

Document Version History

Date	Version	Description	Name
10 Dec 2024	1.0	First Draft (For Development stage)	Robert Ascan
18 Dec 2024	1.1	Updated the TSYS authentication mechanism from API Key to TSYS HMAC as outlined in the TSYS APIs authentication - Financial and Emerging Services - Rogers Wiki . This update corrects a misnomer in previous HLD versions. The TSYS HMAC mechanism has been in place since day one.	Robert Ascan
15 Jan 2025	1.2	Added a new use case (Get Account Info by ANI match), included in the scope for PCI, and further refined descriptions across all sections with additional low-level technical details to enhance design clarity. Updated IAM resources in Section 2.7.4.2, further narrowing the scope of permissions to tighten security. Revised diagrams in Sections 2.5.2 and 2.7 to better illustrate the public cryptographic key handling mechanism. Enhanced Section 2.7 with lower-level technical details to clarify the sensitive cardholder data handling process in call/audio and agent screen recordings. Added AWS Network Firewall to the architecture, following new discovery that TSYS cannot provide a static IP range. These updates do not alter the existing mechanisms for data handling or security controls.	Robert Ascan

Document Naming and Versioning

Incorporate the following naming and versioning conventions:

Document Versioning	
Document Name	Project-id Project-name Deliverable-name.doc
Work in progress file with date stamp	Project-id Project-name Deliverable-name - vyyyy-mm-dd.doc
Work in progress file with tracked updates	Project-id Project-name Deliverable-name - vyyyy-mm-dd Name-Initials.doc
Versioned file	Project-id Project-name Deliverable-name - v1.0.doc

Table of Contents

- Purpose of HLD
- How to Complete this Document
- Document Version History
- Document Naming and Versioning
- 1.0 Business Section
 - 1.1 Business Solution Summary
 - 1.2 Project Objectives
 - 1.3 Solution Summary
 - Referenced Documents
 - 1.4.1 In Scope
 - 1.4.2 Out of Scope
 - 1.4.3 Uses Cases In Scope
 - 1.4.4 Use Cases out of Scope
 - 1.5 Assumptions, Risks and Constraints
 - 1.6 Business Processes/Considerations
 - 1.7 Deployment Approach
- 2.0 Solution Architecture
 - 2.1 Project Context
 - 2.1.1 In-Scope Applications
 - 2.2 Application Communication
 - 2.3 Enterprise Services
 - 2.4 Use Case Realization
 - 2.4.1 Business Processes
 - 2.5.1 Information Model
 - 2.5.2 Data Flow Diagram
 - 2.5.4 Data Container Details
 - 2.5.5 Information Objects
 - 2.6 Data Governance (Rogers Bank)
 - 2.6.1 Data/Information Ownership & Stewardship
 - 2.6.2 Data Lifecycle and Retention
 - 2.6.3 Metadata Management
 - 2.6.5 Provenance and Lineage
 - 2.6.6 Data Integrity and Quality, Ingestion & Extraction
 - 2.6.7 Data Integration
 - 2.6.8 Data Access & Use
 - N/A
 - 2.6.9 Use of Third Parties & Third-Party Data
 - 2.6.10 Data Residency
 - 2.7 Security Architecture
 - 2.7.1 Security Solution View
 - Public Subnet NACL Configuration
 - Private Subnet NACL Configuration
 - 2.7.2 Encryption - Data at Rest
 - 2.7.3 Encryption – Data in Transit
 - 2.7.4 Identity and Access Management (IAM)
 - 2.7.4.2 AWS Applications IAM authorization and access control details
 - 2.8 Other Architectural Characteristics
 - 2.8.1 Availability, Scalability, Reliability and Maintainability
 - AWS Lambda Development & Deployment (CI/CD pipeline)
 - 2.8.2 Disaster Recovery
 - 2.8.3 Response Time
 - 2.8.4 Industry Compliance
 - 2.8.5 Volumetric & Service Level Agreement - High Level Impact Analysis
 - Volumetric & Service Level Agreement - High Level Impact Analysis
 - 2.8.6 Enterprise Application Monitoring
- Technical Solution
 - 3.3 Application 1
 - 3.3.1 Application Overview:
 - 3.3.2 Application architecture/design
 - 3.3.3 Application Security Specifications
 - See section 2.7 Security Architecture

3.5 Infrastructure Solution

entre Replatform

3.5.2 High Level Technical Solution

- 3.5.2.1 Key Concepts
- Refer to Sec. 1.3
- 3.5.2.2 Environments
- DEV, STG, QA, PROD - Same as in Sec 3.5.2.2 of the HLD - Card Viewer (PCI) (refer to the "Referenced Documents" section in Sec 1.3 for the link)
- 3.5.2.3 Locations
- Same as in Sec 3.5.2.3 of the HLD - Card Viewer (PCI) (refer to the "Referenced Documents" section in Sec 1.3 for the link)
- 3.5.2.4 Network Security Zones
- Same as in Sec 3.5.2.4 of the HLD - Card Viewer (PCI) (refer to the "Referenced Documents" section in Sec 1.3 for the link)
- 4.0 Approvals
- 5.0 Appendix
 - 5.1 List of Contributors
 - 5.2 Sign-Off Definitions
 - 5.3 Document Abbreviations

1.0 Business Section

1.1 Business Solution Summary

Rogers bank currently uses outsourced vendors for Contact Centre Technology. The Contact Centre Replatform Project will replace the existing vendor owned technology with Amazon Web Services Connect. The AWS Connect platform will serve as a Service contact centre solution that will reduce operational cost, increase contact centre flexibility and deliver framework for an improved customer experience.

The project will deliver technology capable of enhancing the customer experience by driving improved options for self-service, and empowering contextual interactions across Rogers Bank channels. AWS Connect solution will drive a richer interaction with Contact Centre agents, improving the customer experience by serving context and facilitating a more personalized conversation.

1.2 Project Objectives

- 1) Build Contact Centre platform flexibility and agility by replacing the existing technology stack with AWS Connect Contact Centre as a Service (CCaaS)
- 2) Implement a modernized / future ready digital platform that enables OMNI channel interactions across Rogers Bank service properties
- 3) Enrich Contact Centre interactions by presenting data driven context along with AI enhanced recommendations that drive customer experience.
- 4) Accelerate Contact Centre efficiencies through expanded self service, agent tooling automated workflows and enhanced data

1.3 Solution Summary

The following provides a high-level overview of the solution's architecture, highlighting key components and their interactions within the system:

Overview of PCI Solution for CCR (MVP)

The CCR/RBCONNECT handles sensitive customer "Account Data" as part of its core functionality. To reduce and narrow the PCI DSS compliance scope, RBCONNECT will leverage Rogers Bank's Cardholder Data Environment (CDE), which was created as part of the PCI solution for Instant Credit (IC). This CDE design and implementation are covered in the **HLD - Card Viewer (PCI)** document (referenced in the section "Referenced Documents" below).

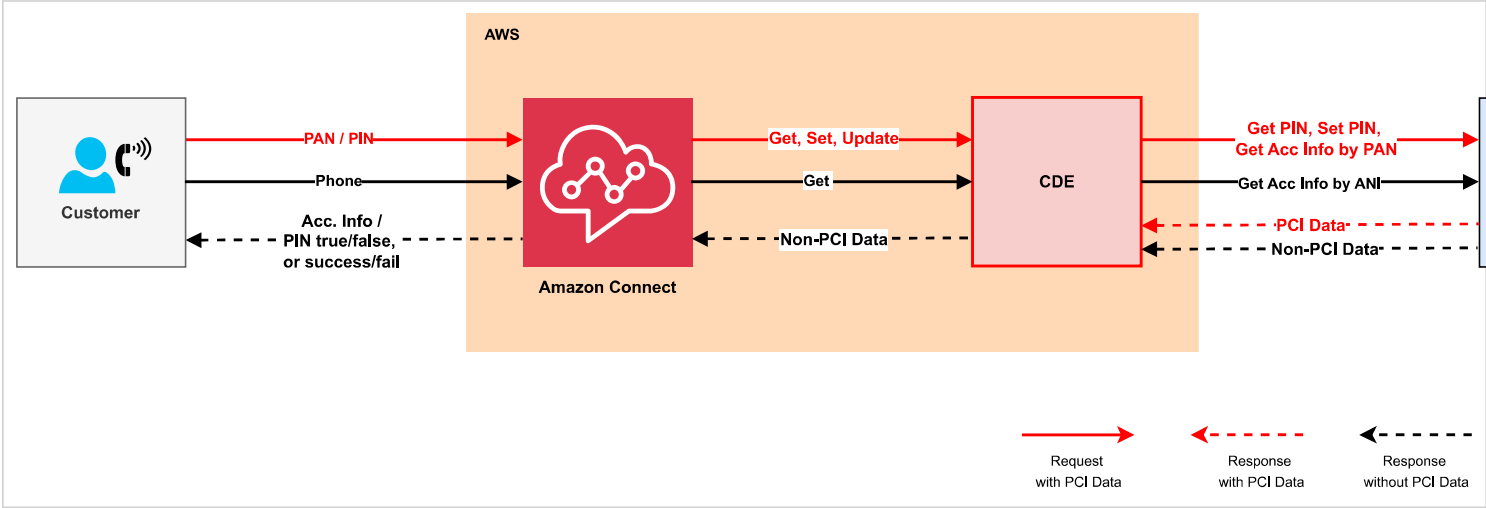
The solution described in this HLD is designed to safeguard sensitive customer data at every stage — from initial data collection in Amazon Connect to secure communication with TSYS and back — ensuring full compliance with PCI DSS standards.

No sensitive authentication data (PIN) is recorded, stored, or logged anywhere in the system (outside of TSYS). All processing of sensitive authentication data is performed in volatile memory (RAM) and is not persistent. Cardholder data (PAN) is not logged anywhere in the system.

Through the use of **robust encryption** methods, secure credential management, and meticulous segmentation and segregation of roles and data, the system ensures that customers can securely set, update, or verify their PINs and retrieve card information. Strong **IAM policies** and secure **authentication and authorization** mechanisms further enhance protection, safeguarding sensitive information while enabling seamless execution of business logic.

This approach delivers a secure, efficient, and user-friendly customer experience.

entre Replatform



Referenced Documents

Provide links and version dates to the additional documents listed below.

Document	Location	Date	Version
Business Requirements Document (BRD)	CMC24-115 - Contact Centre Replatform_ MVP_BRD v1.8_Final.docx	11 Dec 2024	1.8
Use Cases	IVR Flows MVP - Financial and Emerging Services - Rogers Wiki Get Account by ANI API - Financial and Emerging Services - Rogers Wiki		WIP
Cyber STARR	[CST-42303] RB CCR - AWS Connect - Jira Prod (reqcentral.com)		
HLD for CCR MVP (Non-PCI)	High Level Design - Contact Center Re-Platform - MVP (non-PCI) - Financial and Emerging Services - Rogers Wiki (reqcentral.com)		WIP
HLD - Card Viewer (PCI)	High Level Design document - Card Viewer (PCI) - Financial and Emerging Services - Rogers Wiki (reqcentral.com)		WIP

1.4 Scope Statement

1.4.1 In Scope

The in-scope statement should clearly mention the functional deliverables that will be delivered as a part of this solution.

Impacted Area	In Scope	New /Modified
AWS Connect Framework	Amazon Connect: AWS public cloud customer contact center service	Modified
Customer Experience	- Amazon Connect Flows - Identification (PAN, Customer Identification using PAN) - Identification (Phone number, Customer Identification using ANI)	New

Impacted Area	In Scope	New /Modified
	- Self-Services - Update PIN - Set PIN - Verify PIN	
Integrations	TSYS	New
Azure DevOps	DevSecOps (Terraform modules, Azure Pipeline)	Modified
CDE	PCI CDE environment to associate select CCR lambdas with and provide access to TSYS services	Modified

1.4.2 Out of Scope

The Out-of-Scope statement should clearly mention the functionality that will not be delivered as a part of this solution.

Impacted Area	Out of Scope
PCI Environment & Processes	Design of CDE environment including CI/CD infra (Existing)
Non-PCI RBCONNECT Details	The Non-PCI design for RBCONNECT is part of a separate HLD.

1.4.3 Uses Cases In Scope

Category	Use case	Objective	IVR Flow
Identification	Get Account Info by PAN - Identify customers by requesting their 16 digit PAN if ANI (Automatic Number Identification) matching failed.	Ability for an Agent to request customer's PAN and use it to manually look up the account in TCS GUI.	Get Account by ANI API - Financial and Emerging Services - Rogers Wiki
Identification	Get Account Info by ANI - Identify customers using their phone number from which they are calling (ANI Match)	Ability to get customer details using the phone number the customer calling from, instead of asking to enter the PAN.	Get Account by ANI API - Financial and Emerging Services - Rogers Wiki
Self-service - PIN functions	PIN Update - As a user I would like to change PIN for my existing card.	- Ability to set or update PIN. - Ability to authenticate user based on PIN.	IVR Flows MVP#ChangePIN
	PIN Set - As a user I would like to set my PIN for my new card.		IVR Flows MVP#ChangePIN
	PIN Verify - As an agent, I can redirect customer/user to complete PIN authentication and get the Authentication status back in agent desktop.		IVR Flows MVP#PINValidation
	PIN Verify - As a system user I need to validate my card PIN to confirm authentication and gain secure access to specific services.		IVR Flows MVP#PINValidation

1.4.4 Use Cases out of Scope

- Non-PCI Use cases
- End to End flow from Non-PCI to PCI and back to Non-PCI

1.5 Assumptions, Risks and Constraints

Assumptions	Impacted application	Assumption Verified	Due date	Impact
CDE is/will be PCI-DSS	RBCONNECT			

entre Replatform				
Compliant				
Existing DevSecOps will be used as adopted for CDE	RBCONNECT			

Constraints/Dependencies/Limitations

ID	Constraint/Risk/Dependencies/Limitations	Impacted Stakeholders & Risk Response
1	PCI data leakage	Same as CDE environment
2	Account Compromise	Same as CDE environment
3	Project timelines due to environment creations, updates and process specific delays	

1.6 Business Processes/Considerations

N/A

1.7 Deployment Approach

Exiting CDE DevSecOps workflow will be used to deploy application.

Phase/Single Drop	Components included	PVT (Y/N)	PET (Y/N)	BRT (Y/N)
Drop 1	Lambdas	Y	Y	N

Deployment Units (Prod/UT/QA/Dev)

#	Unit type	Name	Runtime Version
1	lambda	GetAccountByCard	nodejs22.x
2	lambda	GetAccountByANI	nodejs22.x
3	lambda	VerifyPIN	nodejs22.x
4	lambda	ChangePIN	nodejs22.x
5	Secret Manager	<env>/tsys/RBCONNECT_API_KEY	N/A
6	KMS	??	N/A

Deployment Method:

#	Module Type	Method	Details
	Lambda	TFM	
	Secret Manager	N/A	CloudOps
	KMS	NA	CloudOps
	IAM roles	N/A	CloudOps

2.0 Solution Architecture

2.1 Project Context

This diagram illustrates the overall scope of the CCR project, encompassing both PCI and Non-PCI data paths. However, the design for the Non-PCI use cases is covered in a separate document, the **HLD for CCR MVP (Non-PCI)** (refer to "Referenced Documents" in Sec 1.3 for the link).

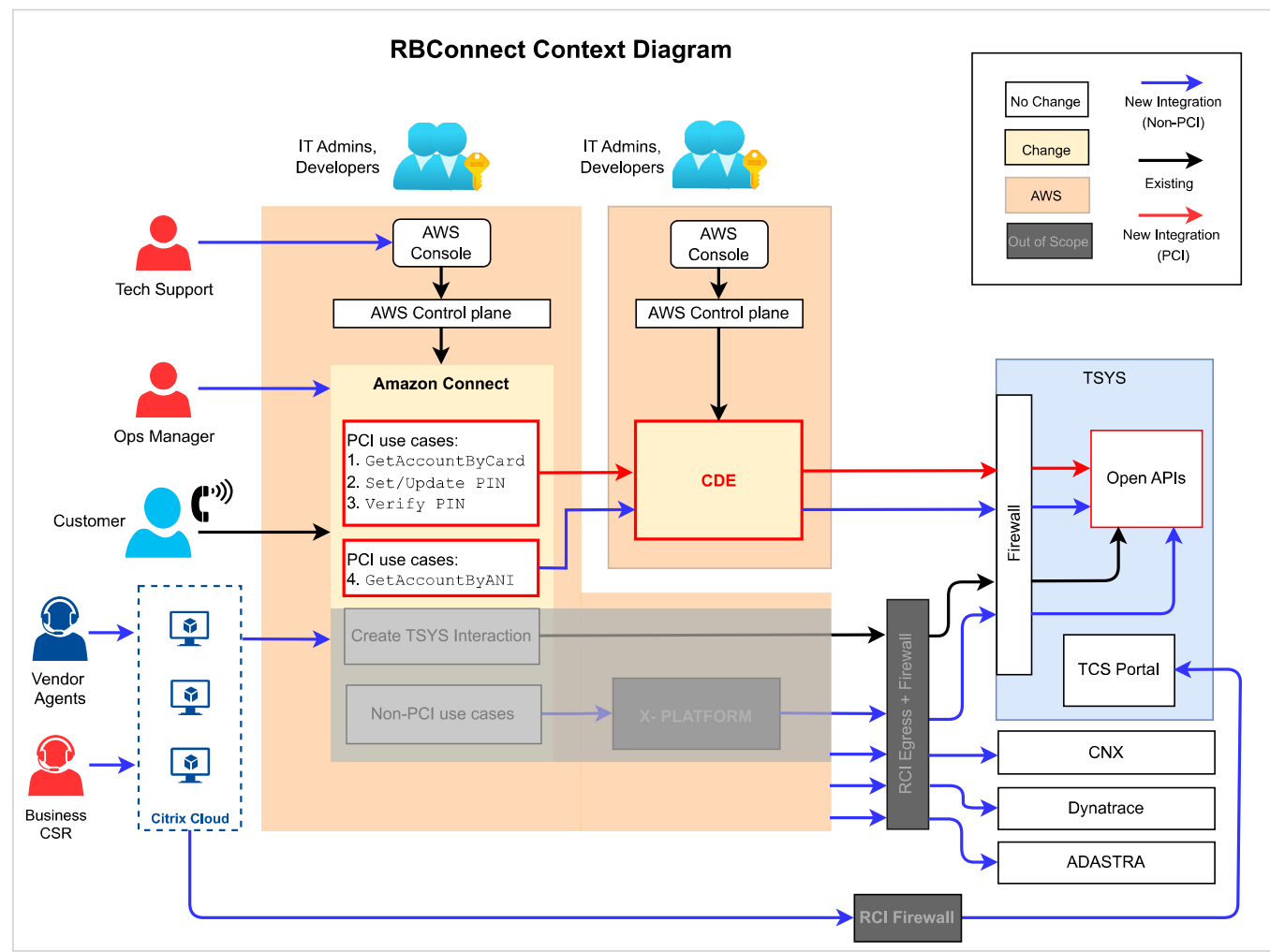
The RBCONNECT solution utilizes an existing CDE hosted in a separate AWS account (see **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link)).

The PCI data path is highlighted in **RED** for clarity - refer to the diagram legend for more details.

The return path from the CDE does not contain any PCI data.

For both PCI and Non-PCI data paths, no network modifications are required (e.g., TSYS whitelisting or changes to RCI/RB egress configurations), as these setups are already in place.

To implement PCI use cases for RBCONNECT, a few Lambda functions and encryption keys will be associated with the CDE VPC.



NOTE: From this point forward, the focus shifts to the PCI pathway of the project. Details regarding the CDE are documented in the **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link).

2.1.1 In-Scope Applications

<< For each app in the Project Context diagram, provide the following details. The HLD will not be approved if any impacted application, new or existing, is not correctly recorded in the [Application Inventory](#). >>

App ID	App Name	New / Change	Description of the Apps	App Classification
1991	RBCONNECT	Change	Cloud-based contact center implementation	Important

entre Replatform				
			(focusing only on PCI path)	
N/A	TSYS (PCI interface)	Out of scope	N/A	Important
N/A	CDE	New	CCR PCI Lambda functions to be deployed in the CDE VPC: ◦ ChangePin (Card PIN Set/Update use case) ◦ VerifyPin (Card PIN Verify use case) ◦ GetAccountByCard (Get Account Info using PAN use case) ◦ GetAccountByANI (Get Account Info using ANI match use case)	Important

2.2 Application Communication

N/A

2.3 Enterprise Services

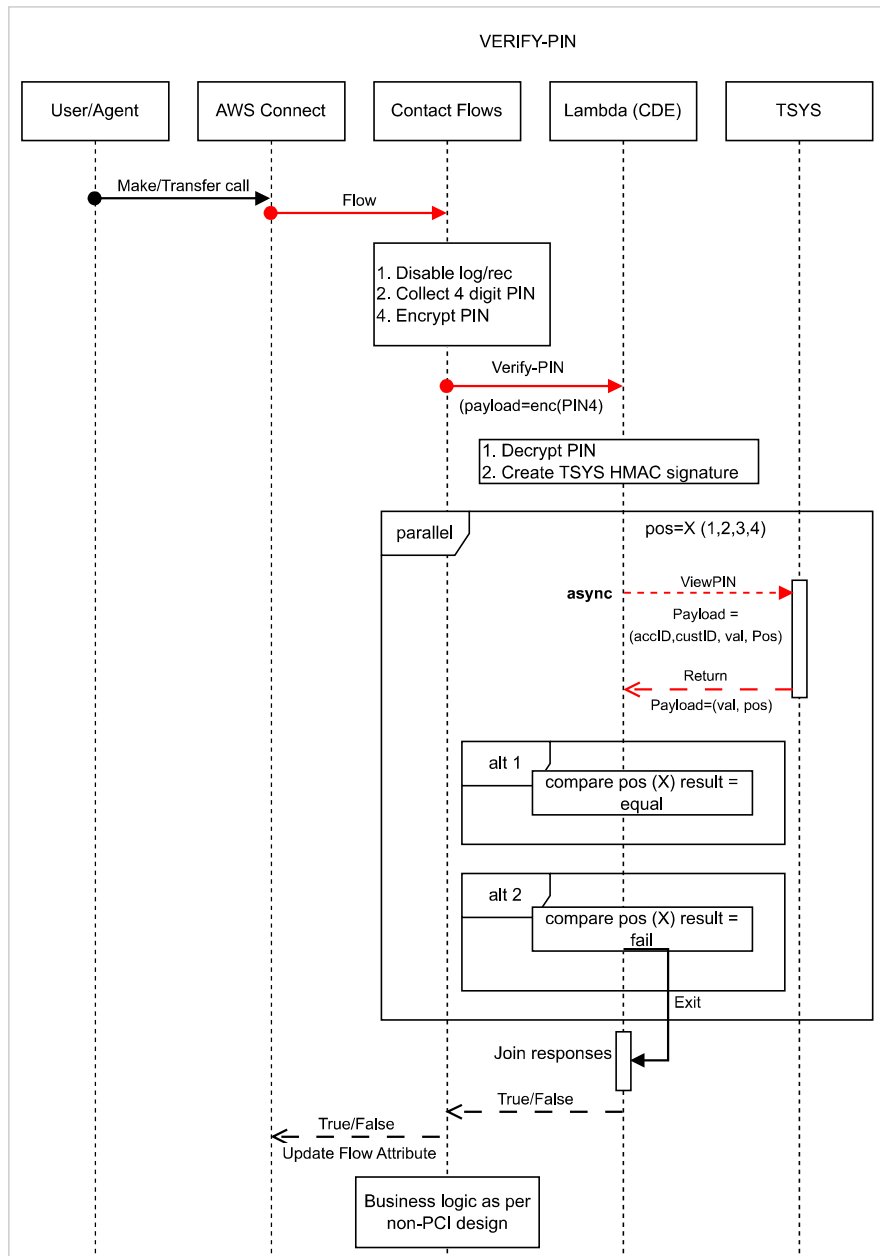
<< List the Enterprise Services that will be used in this solution. >>

Service Name	Producing Application	New Existing
Amazon Connect	Amazon Web Services	Existing (from Non-PCI account)
Amazon S3	Amazon Web Services	Existing
AWS Lambda	Amazon Web Services	Existing
AWS IAM	Amazon Web Services	Existing
AWS Secret Manager	Amazon Web Services	Existing
AWS CloudWatch	Amazon Web Services	Existing
AWS X-Ray	Amazon Web Services	Existing
AWS CloudTrail	Amazon Web Services	Existing
Azure DevOps	Microsoft	Existing
GitHub Version Control	GitHub	Existing
Registry	JFrog Artifactory	Existing

2.4 Use Case Realization

Note: For simplicity, the following diagrams do not depict data flows involving AWS-managed services like Secrets Manager and KMS.
[entire Replatform](#)

• Verify PIN

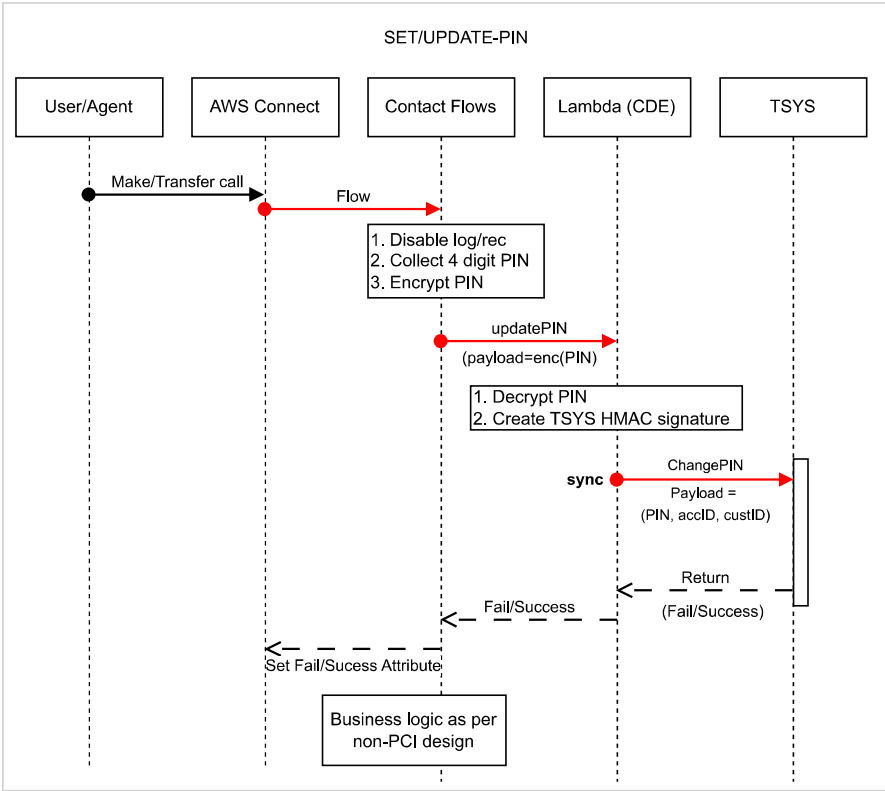


Verify PIN Use Case - ASYNC API Requests:

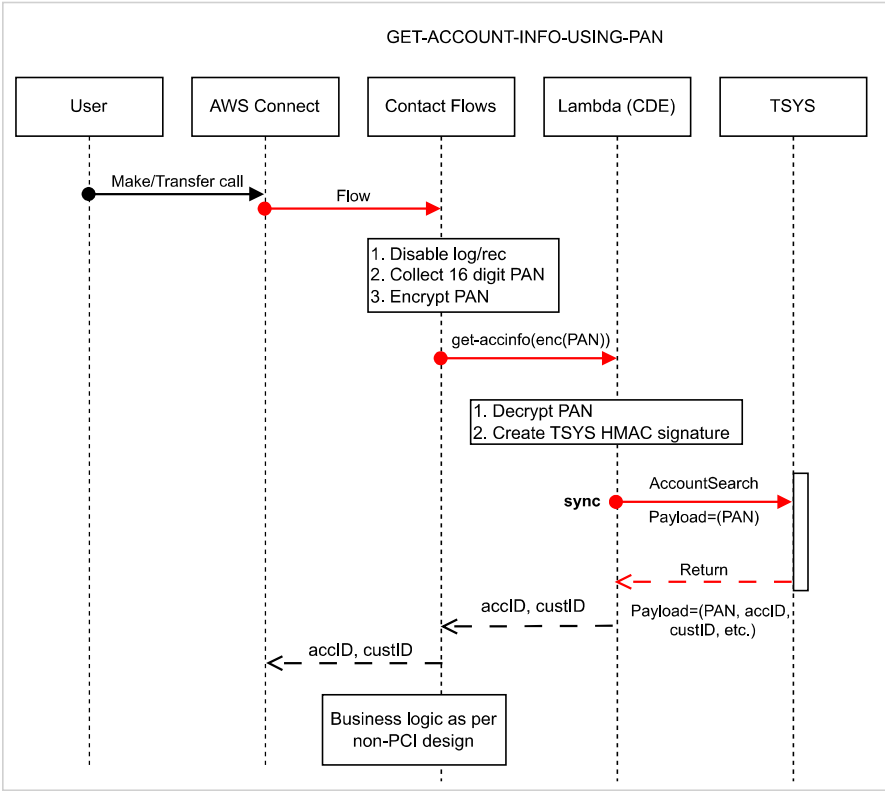
- For verifying a PIN, the Lambda function checks all four PIN positions against TSYS asynchronously to optimize performance.
- The Lambda function sends four independent ASYNC API requests to TSYS, each checking a specific PIN position.
- These requests are processed in parallel, meaning the "request" does not wait for the server's response before continuing.
- Once all responses are received, the Lambda function aggregates them and compares them to form a consolidated result (Success/Fail).
- The aggregated result is returned to the caller, ensuring efficient and accurate PIN verification.
- The workflow is **blocking**, meaning no further processing occurs until the response is received.
- Processing all PIN positions in parallel significantly speeds up the verification process.

• Set / Update PIN

entre Replatform

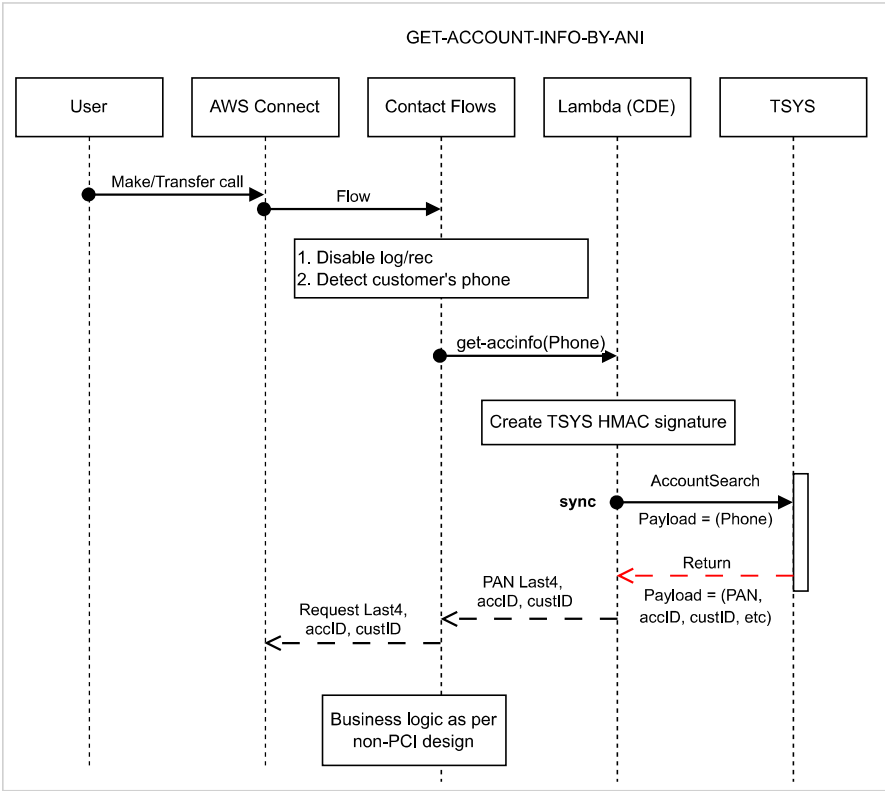


• Get Account Info by PAN



• Get Account Info by ANI

entre Replatform



Get Account Info by PAN, Get Account Info by ANI and Set/Update PIN Use Cases - SYNC API Requests:

- These use cases require immediate processing and response from the TSYS system.
- For instance, when retrieving card information (incl. accountID, customerID and PAN), or setting/updating a PIN, the Lambda function makes a synchronous API call to TSYS.
- The Lambda function waits for the response from TSYS before proceeding further. The caller / Amazon Connect Contact Flow is paused until the response is received before moving forward.
- The workflow is **blocking**, meaning no further processing occurs until the response is received.
- SYNC requests ensure reliability and maintain sequential integrity, which is critical for these types of operations.

2.4.1 Business Processes

Identify the Business Processes that will be impacted as a part of this solution. The business process(s) should map it to [TMForum Business Process \(eTOM\) Framework](#).

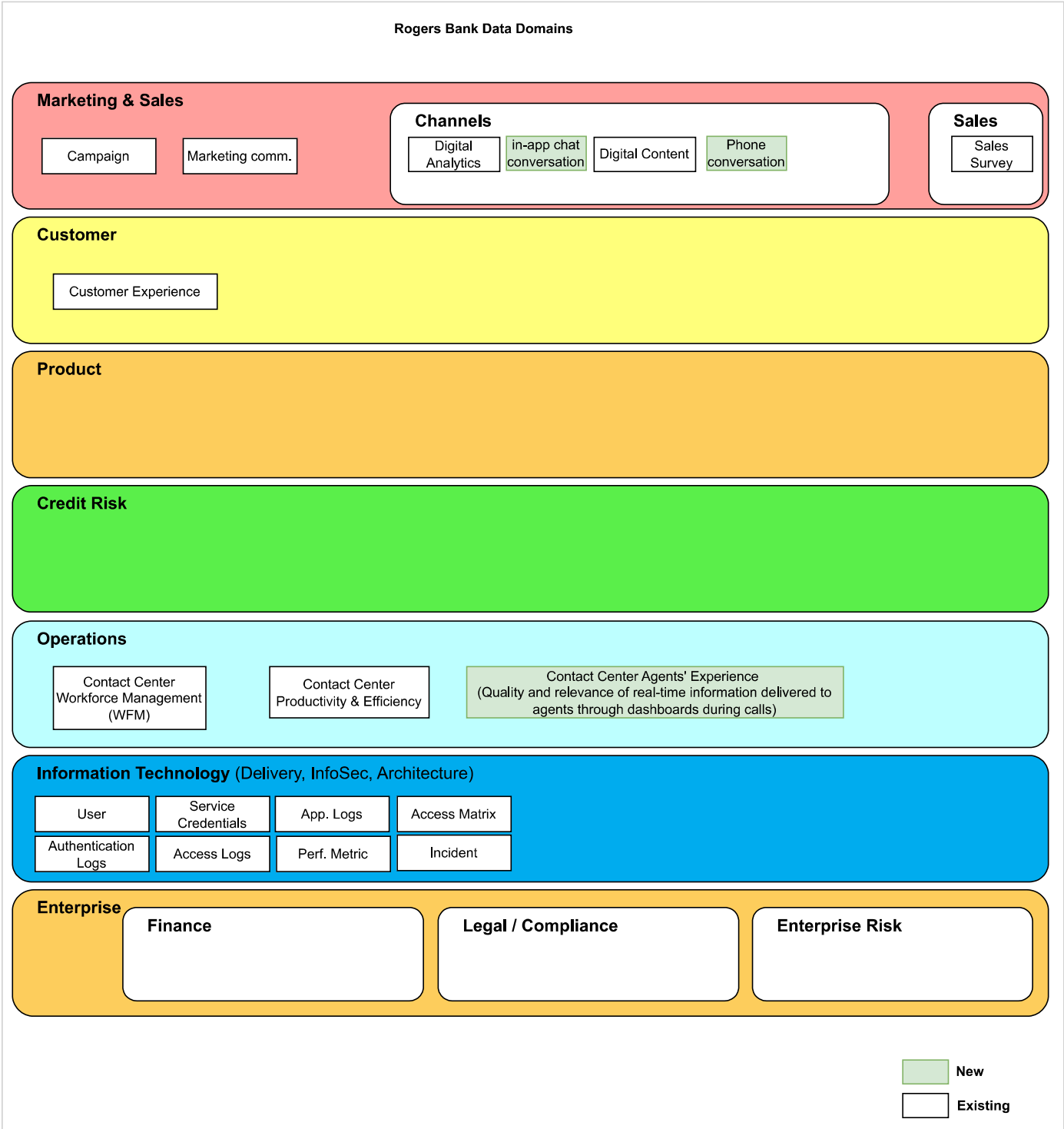
TMForum Business Processes can be found [here](#).

Entity/Actor	Change/Impact
Customer	No direct impact, customer gets secure environment for authentication and PIN functions
Administrator	No change
Supervisor	No change
Agent	No change
IT Admins	PIN/PAN function related issues can't be troubleshooted in Non-PCI environment
Workforce Manager	No change

2.5 Data Architecture

2.5.1 Information Model

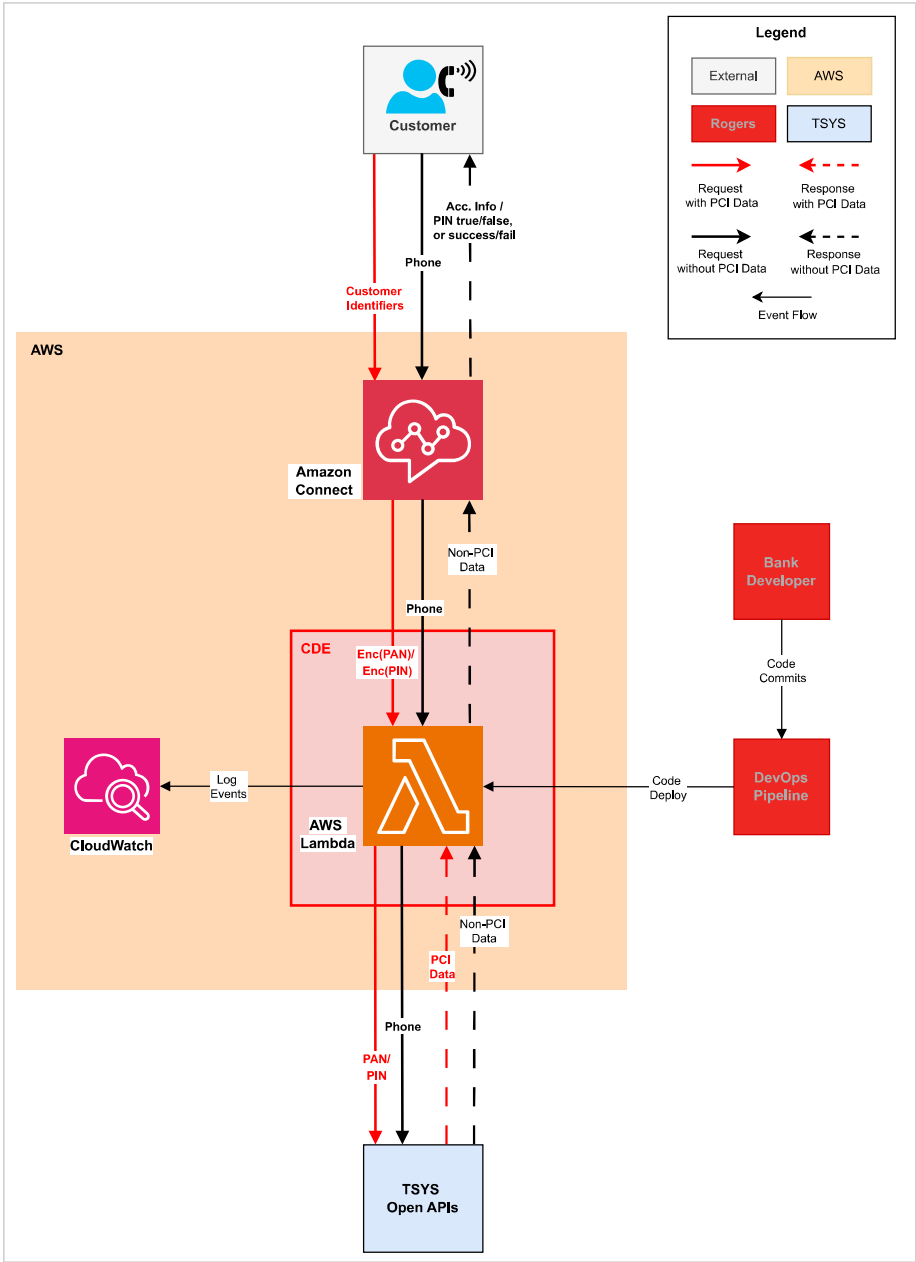
Identify Domains and Entity (L1) that wil be impacted as a part of this solution.



2.5.2 Data Flow Diagram

This is a high-level diagram showing end-to-end data flow.

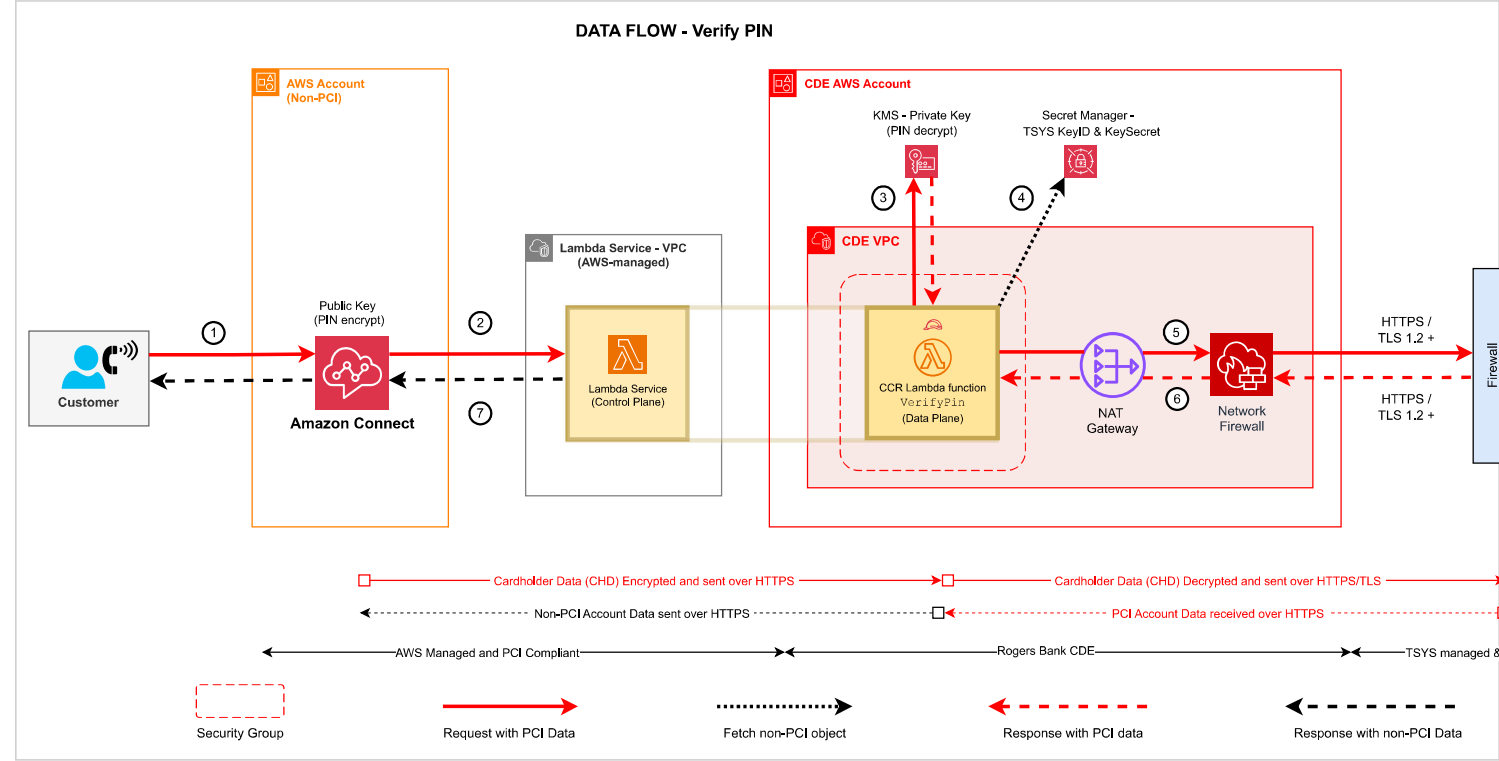
entre Replatform



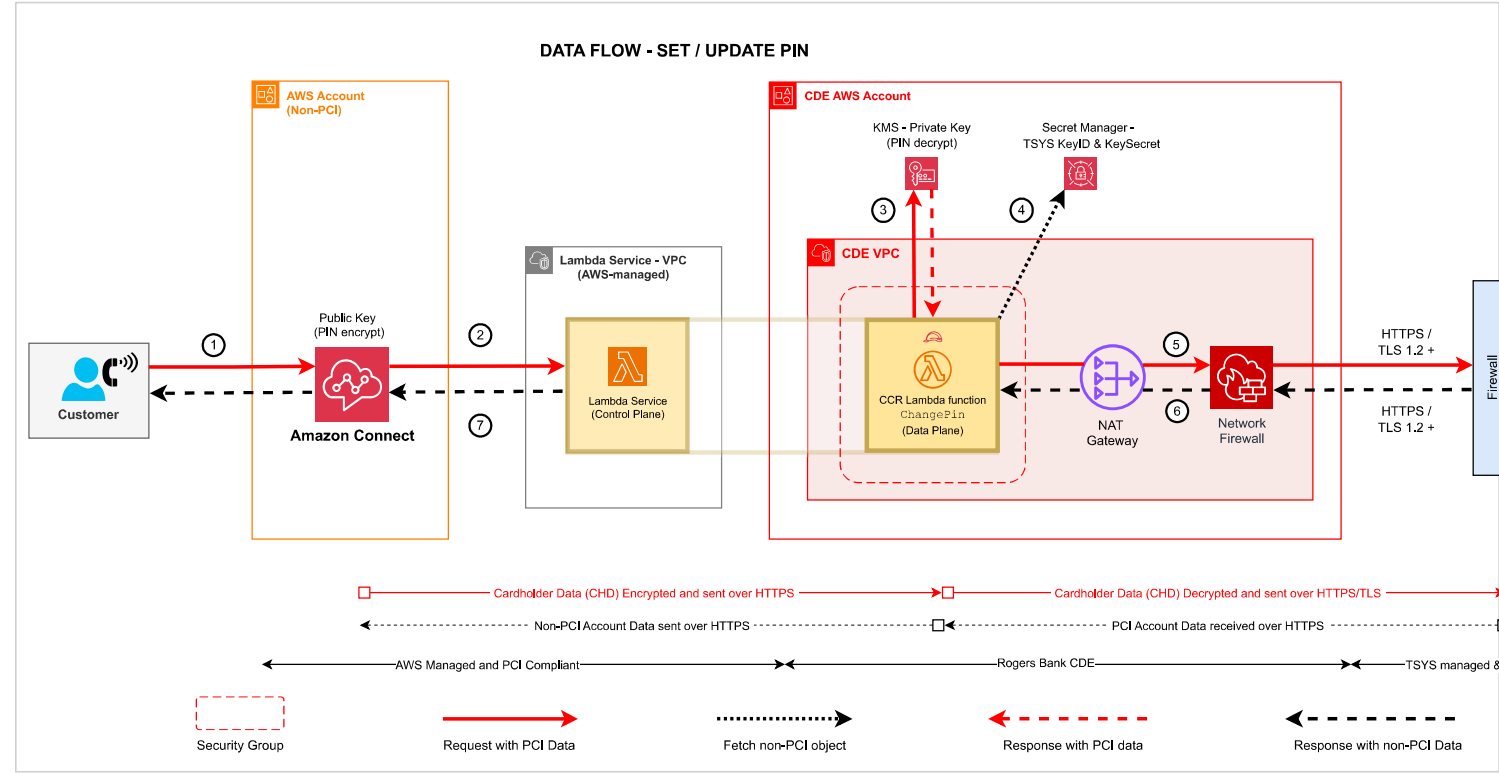
The following diagrams explains **Account Data path** for each use cases:

- **Verify PIN**

entre Replatform

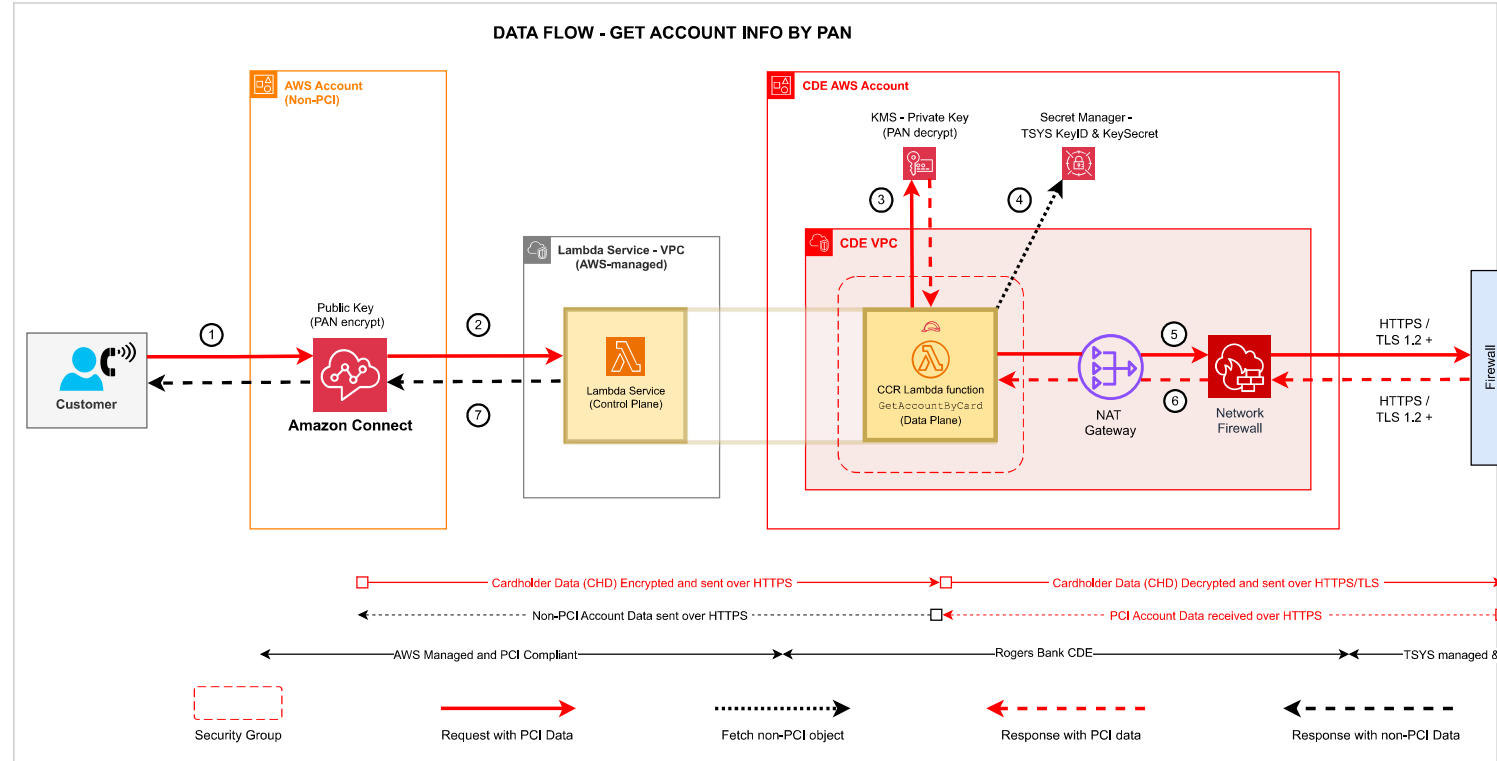


• Set / Update PIN

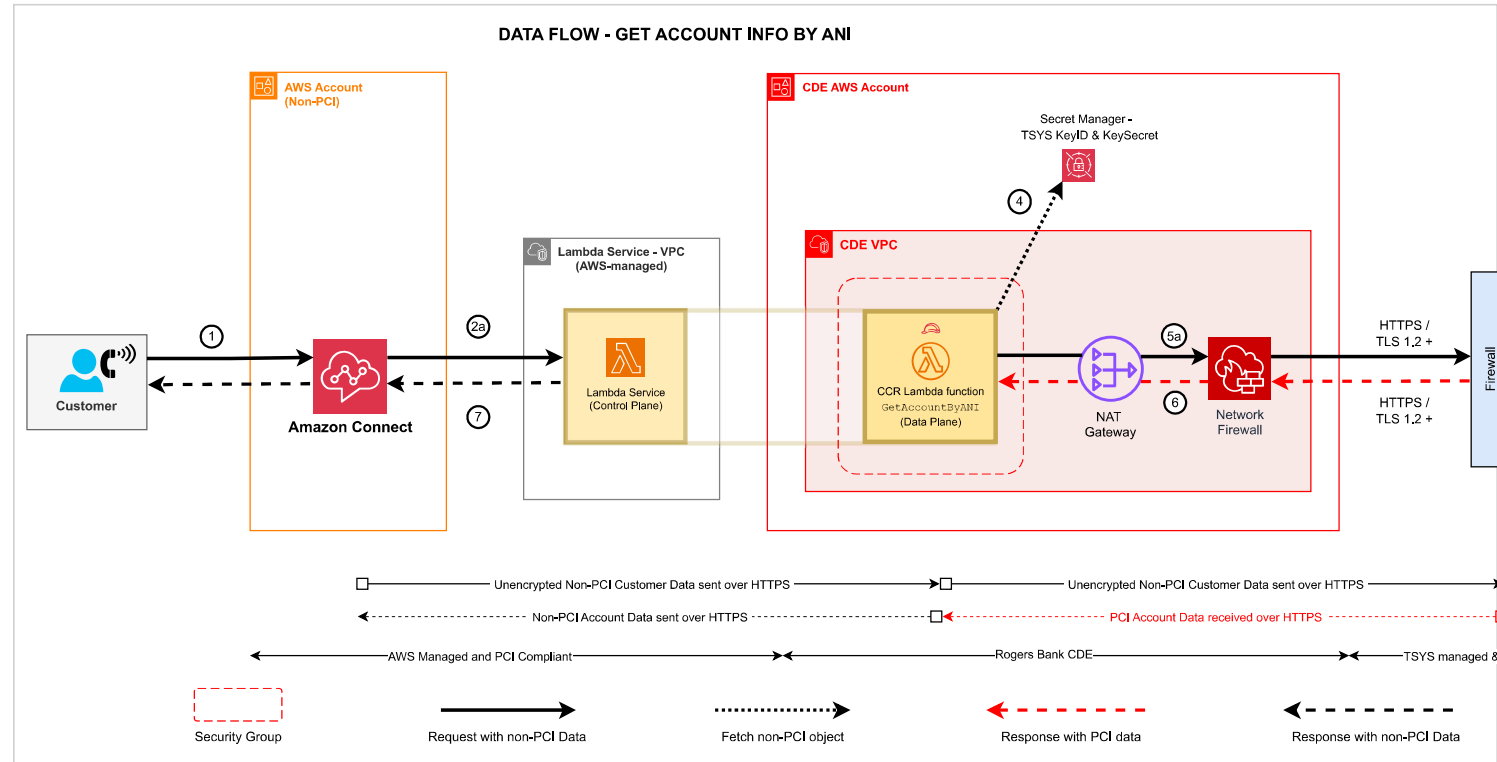


• Get Account Info by PAN

entre Replatform



• **Get Account Info By ANI match**



The following table outlines the flows (for all four PCI use cases combined), triggered when Amazon Connect invokes any of the PCI use cases within scope:

ID	Req ID (Y/N)	ORIGIN	DESTINATION	DETAILS
1	Y	PSTN → SIP	Amazon Connect - Contact/IVR Flows	When a customer's call is connected to Amazon Connect, the platform or an agent initiates a Contact Flow that triggers a self-service PCI workflow to handle the interaction based on the configured call-routing logic. The data is encrypted using a public key stored in Amazon Connect. This encryption* is handled internally by Amazon Connect. The encrypted data is then passed as a flow attribute to the Amazon Connect workflow for further handling. Data: PAN, PIN
1a	N	PSTN → SIP	Amazon Connect - Contact/IVR Flows	When a customer's call is connected to Amazon Connect, the platform initiates a Contact Flow that triggers a self-service PCI workflow to handle the interaction based on the configured call-routing logic. Customer's phone number from which call is received is passed as an attribute in Contact Flow for further handling and to get customer details Data: Customer's phone number
2	Y	Amazon Connect	Lambda	When a customer or an agent selects a PCI use case, the associated AWS Lambda function is invoked by Amazon Connect. The Lambda function is configured to run within the CDE VPC and private subnet with tightly configured security groups, ensuring enhanced network isolation. AWS manages the internal segmentation of Lambda functions to further contribute to PCI DSS compliance. The Lambda function processes event objects containing sensitive data, such as the PAN or PIN. This data is securely transmitted via encrypted RESTful APIs (over HTTPS with TLS 1.2 or higher) to TSYS to retrieve or update customer account information. Data: Encrypted PAN/PIN.
2a	N	Amazon Connect	Lambda	When a customer or an agent selects a PCI use case, the associated AWS Lambda function is invoked by Amazon Connect. For PCI compliance, the Lambda function is configured to run within the CDE VPC and private subnet with tightly configured security groups, ensuring enhanced network isolation. AWS also manages the internal segmentation of Lambda functions, contributing to compliance with PCI DSS requirements. The Lambda function processes the event payload, extracting the customer's phone number (provided as an attribute of the event). It securely transmits this data via encrypted RESTful APIs (HTTPS with TLS 1.2 or higher) to TSYS to retrieve customer account information. This configuration ensures compliance with PCI DSS guidelines, including secure transmission, data access controls, and secure connectivity within the private network. Data: Customer's phone number
3	Y	Lambda	AWS KMS	When the Lambda function receives an encrypted payload from Amazon Connect, it calls AWS KMS via the AWS SDK, invoking the <code>Decrypt</code> API. The encrypted data is securely sent to KMS over HTTPS, secured with TLS 1.2 or higher. Since the payload was encrypted with the public key of an

entre Replatform				
				asymmetric key pair, AWS KMS uses the corresponding private key (stored exclusively within KMS) to decrypt the data. KMS then securely returns the decrypted plaintext to the Lambda function over the same encrypted connection. This ensures that the decryption process is securely performed within KMS and that the sensitive data is only accessible to authorized Lambda functions operating within the secure CDE. Data: ◦ Lambda→KMS: Encrypted PAN/PIN; ◦ KMS→Lambda: plaintext PAN/PIN
4	N	Lambda	AWS Secrets Manager	The Lambda function securely retrieves the TSYS API credentials (KeyID and KeySecret) from AWS Secrets Manager. These credentials are used to generate an HMAC signature, authenticate requests, and establish secure interactions with TSYS systems. (For more details about the authentication process, refer to Section 2.7.4.1 "Authentication" in this HLD.) Data: TSYS KeyID and KeySecret
5	Y	Lambda	TSYS	The Lambda function sends an authenticated HTTPS request to TSYS, first processed by the NAT Gateway, which acts solely as a pass-through service. The request then flows through the AWS Network Firewall. Domain-based firewall rules in AWS Network Firewall ensure only traffic to the TSYS domain is allowed. The NAT Gateway forwards encrypted traffic without inspecting, modifying, or storing data payloads, ensuring no CHD is logged, stored, or persistently processed. The request includes sensitive data such as the PAN and PIN, secured using an HMAC-based authentication header. This header is dynamically constructed using the TSYS KeyID and an HMAC signature generated with the TSYS KeySecret, both securely retrieved from AWS Secrets Manager. Data: ◦ PAN/PIN ◦ TSYS KeyID ◦ HMAC signature generated using TSYS KeySecret
5a	N	Lambda	TSYS	Same as in # 5 except for the payload content. The request includes customer's phone number, and it is secured using an HMAC-based authentication header. Data: Customer's phone number
6	Y	TSYS	Lambda	PCI data returned by TSYS to the Lambda function is securely encrypted and transmitted over HTTPS with TLS 1.2 or higher, ensuring end-to-end encryption during transit. This secure communication adheres to PCI DSS encryption requirements, enabling the Lambda function to validate and process the returned data without exposing sensitive information. Data: ◦ Verify PIN use case: PIN (encrypted with TLS 1.2 or higher). ◦ Set/Update PIN use case: Success status (True/False).

entre Replatform				
				- Get Account Info by PAN use case (all encrypted with TLS 1.2 or higher): - PAN, - accountID, - clientID, - customer's phone number, - Other account info. - Get Account Info by ANI Match use case (all encrypted with TLS 1.2 or higher): - PAN, - accountID, - clientID, - customer's phone number, - Other account info.
7	N	Lambda	Amazon Connect	The Lambda function sets non-PCI data , such as PAN Last4 digits, accountID, clientID, and a success status (True/False), as contact flow attributes. After setting these attributes, the Lambda function continues to execute non-PCI business logic, ensuring that sensitive PCI data is excluded from this stage of processing.

* Wrapping algorithm used by Amazon Connect to encrypt PAN or PIN => "RSA/ECB/OAEPWithSHA-512AndMGF1Padding";

2.5.3 Data Integration Details

Describe the Data Integration Details for the application. This should include following details for each Integration. Include the data integration diagram.

Int #	Source System	Target System(s)	Initial Load / One Time On-Going Lead	Interface Type (Real Time/Batch)	Description	Technology
1	RBCONNECT	TSYS	Ongoing	Real Time	HTTPS (multiple interactions)	REST API

2.5.4 Data Container Details

Provide the information for Data containers where data will be persisted. This could be a typical DBMS(Oracle, SQL Server) or a typical cloud storage like AWS S3 or Azure Blob.

ID	Type	Database Name	Platform	Provider	Change Description
1	LogGroup	AWS CloudWatch	Cloud	AWS	Solution components, including Amazon Connect and AWS Lambda, leverage AWS n CloudWatch to log events in their respective LogGroups. This centralized logging enables monitoring, troubleshooting, and auditing of system activity across the solution.
2	Log backup	AWS S3	Cloud	AWS	used to backed up cloud watch log
3	Source control	GitHub	Cloud	MS	New lambda source code and configuration

2.5.5 Information Objects

Describe the list of entities that will be utilized as a part of this solution. Also identify name of the system that is system of records for this data.

All new Entity/Attribute defined as a part of the project should follow naming conventions.

For Logical Naming Conventions follow TMForum Information Model.

Application Name	Domain Name	L1 Domain	Information Object Name	Object Type	Change Description
RBCONNECT	Product	Self-Serve	AccountID, ClientID	Numeric	Retrieved from TSYS
TSYS	Product		KeyID, KeySecret	Alpha-numeric String	Used for authentication with TSYS. (For more details about the authentication process, refer to Section 2.7.4.1 "Authentication" in this HLD.)
RBCONNECT	Customer	Self-Serve	PIN, PAN	Numeric	Received from Customer
RBCONNECT	Customer	Automatic	Caller's Phone Number	Numeric	ANI match
RBCONNECT	Product		Public-Private Key	X.509, PEM format	Used to encrypted and decrypt PIN/PAN

2.6 Data Governance (Rogers Bank)

THIS SECTION MUST BE COMPLETE FOR ALL PROGRAMS/PROJECTS WHERE DATA IS BEING COLLECTED, CREATED, MIGRATED, EXTRACTED, TRANSFORMED, LANDED or UTILIZED IN ANY MANNER NOT MENTIONED HERE TO DELIVER THE BUSINESS or IT OUTCOME.

The following Project intake must be completed [DGC Project Intake | Colibra](#) whenever data is being created, modified, or updated. This includes schema creation or modification, table creation and modification, and any data migration projects. Data Dictionaries must be provided for each deployment.

2.6.1 Data/Information Ownership & Stewardship

- Marketing domain - Bank Ownership TBD
- Legal Domain - Beth Posno
- Call domain - Bank Ownership TBD

2.6.2 Data Lifecycle and Retention

Please describe the process and the retention period utilized to appropriately archive and purging data in compliance with Rogers standards. (2 plus current year – low latency access, high latency/offline storage of data up to 7 years, and subsequent purge process).

Data	Retention	Remark
PIN	N/A	Not stored anywhere
PAN	N/A	Not stored anywhere
Phone number	N/A	Not stored anywhere
KEYS	6 months	Recommended duration

2.6.3 Metadata Management

N/A

2.6.4 Data Classification & Privacy

Data	Class	Remark
PIN	Confidential	PCI-Cardholder Data, not stored anywhere
PAN	Confidential	PCI-Sensitive Data, not stored anywhere

entre Replatform		
KEYS	Internal	Private Keys to decrypt PCI data at lambda runtime are stored in KMS provisioned in CDE AWS account
AccountID	Restricted	not stored anywhere
CustomerID	Restricted	not stored anywhere

Please note: column level classification is not required for HLD sign-off, but is required prior to implementation.

2.6.5 Provenance and Lineage

N/A

2.6.6 Data Integrity and Quality, Ingestion & Extraction

BAU - No change as part of the current solution

2.6.7 Data Integration

N/A

2.6.8 Data Access & Use

The new solution will implement replacement data flows so the same data can continue to land in Rogers Bank Data and Analytics environment.

The access control process on that environment is executed as per Bank's standards and procedures. Only allowed Bank personnel has access to it.

N/A

2.6.9 Use of Third Parties & Third-Party Data

N/A

2.6.10 Data Residency

The data handled by RBCONNECT solution will be stored in one AWS Region (Canada Central1), possibly replicated to Canada West in future phase.

2.7 Security Architecture

All services used will abide by ICSU security controls listed at <https://reqcentral.com/plugins/servlet/eazybi/accounts/153/cubes/Assets/reports/5054-11-cloud-controls-list>

Where no security controls currently exist, the process will be followed to ensure new controls, approvals and exemptions as needed are provided.

Architecture Overview:

Amazon Connect integrates with TSYS back-end systems via AWS Lambdas in the Cardholder Data Environment (CDE). All egress to TSYS passes through AWS Network Firewall (with domain-based filtering) and the NAT Gateway, maintaining a secure, PCI-compliant path:

Multi-Factor Authentication (MFA) for Access:

Amazon Connect enforces MFA for all user and administrator access, ensuring secure authentication to meet compliance requirements.

No PIN in Call and Screen Recordings:

Sensitive Authentication Data (SAD) are not captured in call and screen recordings within Amazon Connect, adhering to PCI DSS guidelines and ensuring sensitive data is not inadvertently exposed.

PCI Data in Transit:

All PCI data transmitted from the Cardholder Data Environment (CDE) to TSYS (Rogers Bank's third-party system of record) is sent over HTTPS using TLS 1.2 or higher. Similarly, any PCI data returned by TSYS to the CDE is also transmitted via HTTPS with TLS 1.2 or higher. Beyond these secure exchanges with TSYS, no PCI data leaves the CDE account.

Role of Lambda Functions:

AWS Lambda functions are invoked by Amazon Connect based on contact flow logic, serving as the primary processors for customer requests. The Lambda functions designated for PCI-related use cases include:

- `GetAccountByCard`: Retrieves customer account information using 16 digits PAN.
- `GetAccountByANI`: Retrieves customer account information using ANI match.
- `VerifyPin`: Verifies the PIN using TSYS APIs.
- `ChangePin`: Updates or sets a new PIN securely.

Frequent Compliance Audits:

Regular compliance audits are required to validate the secure handling of data within Amazon Connect and its integration with the CDE, ensuring continuous adherence to PCI DSS standards.

Traffic Flow and Communication:

entre Replatform

Get Account Info by PAN, Get Account Info by ANI and Set/Update PIN Use Cases:

The respective Lambda functions use synchronous (SYNC) TSYS API requests to ensure immediate processing and response for these operations.

Verify PIN Use Case:

The Lambda function sends asynchronous (ASYNC) TSYS API requests in parallel for all four PIN positions. It then aggregates the responses and returns the consolidated result to the caller (Amazon Connect Contact Flow).

General Flow:

The Amazon Connect invokes the appropriate *Lambda → Private Subnet → NAT Gateway → AWS Network Firewall (domain filter) → Internet Gateway → TSYS domain* path. TSYS process the request and sends the response back through the same flow in reverse. Amazon Connect resumes execution of non-PCI logic upon receiving the Lambda result.

Security Considerations:

The PCI compliance of the CDE is addressed in detail the **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link). This section highlights specific changes related to RBCONNECT PCI use case integrations:

Encryption at Amazon Connect:

Amazon Connect leverages a combination of asymmetric and symmetric cryptographic methods, in accordance with PCI DSS requirements, to ensure the secure handling of sensitive account data.

End-to-End Traffic Encryption:

All API traffic between the Lambda functions and TSYS is encrypted in transit end-to-end using TLS 1.2 or higher, ensuring sensitive data remains protected during transit.

Encryption of Data at Rest:

No sensitive data is stored at rest.

Secure Credential Management:

TSYS API credentials (KeyID and KeySecret) are securely stored in AWS Secrets Manager. These credentials are retrieved by the Lambda functions at runtime via secure AWS SDK calls.

Enhanced Traffic Security:

Security groups are configured for each Lambda function running in a VPC and are attached to the Elastic Network Interfaces (ENIs) created during function execution. Inbound rules allow traffic from Amazon Connect, while outbound rules allow HTTPS (port 443) to the NAT Gateway. These security groups act as virtual firewalls, controlling inbound and outbound traffic to and from the Lambda function based on defined rules.

After the Lambda sends outbound traffic, it flows to the NAT Gateway, which forwards the encrypted request to the AWS Network Firewall. The firewall then enforces domain-based filtering (allow-listing) for TSYS before the traffic proceeds to the Internet Gateway. This design ensures that only traffic to the TSYS domain is permitted, providing an additional layer of security and monitoring.

NOTE: It is assumed that the CDE is fully PCI-compliant (**expected to be**), including the implementation of required processes, the assignment of roles and responsibilities to personnel, and the monitoring of logs and access through foundational AWS services.

Secrets Manager and IAM Roles:

IAM Roles Configuration:

Each Lambda function is configured with a dedicated AWS IAM role, ensuring role separation and fine-grained access control. These roles are assigned to the Lambda execution environments, respectively, allowing them to securely retrieve secrets from AWS Secrets Manager without embedding credentials in the container images or using environment variables. This approach adheres to the principle of least privilege, ensuring that each Lambda function can access only the secrets and resources it is explicitly authorized to use. (For further info, refer to Sec 2.7.4.2)

Secure Secrets Management:

All sensitive data, including the TSYS KeyID and KeySecret, are securely stored in AWS Secrets Manager. According to TSYS documentation, these keys have an expiration time, necessitating a rotation process. TSYS is expected to send notification emails in advance of expiration. This approach minimizes the risk of credential compromise and supports compliance with security best practices and PCI DSS requirements.

Secure Communication:

Data Privacy in Amazon Connect:

Audio Recording

Call recording must be enabled and configured in the Amazon Connect instance using the "Set recording and analytics behavior" block within contact flows.

PIN: To avoid capturing PINs (classified as Sensitive Authentication Data (SAD) in PCI DSS) in audio recordings, use the `SuspendContactRecording` and `ResumeContactRecording` APIs to programmatically pause and resume call recordings whenever PIN is collected. These APIs can be invoked directly within contact flows to ensure no PIN is recorded.

PAN: Amazon Connect records customer calls (audio) and stores them in Amazon S3. There is a strong business requirement for retaining of call recordings containing the PAN for a specified period (possibly up to 7 years - **TBC**). To comply with PCI DSS, these recordings must:

- Be securely encrypted at rest.
- Have access restricted to authorized personnel via Role-Based Access Controls (RBAC) to protect sensitive information.

Note: Call audio recordings are stored in a dedicated S3 bucket created in the *CDE AWS account*. Amazon Connect instance (created and running in *RB Default AWS Account (non-PCI)*) is configured to send the recordings to this S3 bucket.

Screen Recording

To facilitate agent screen recording functionalities [Amazon Connect Client Application](#) must be installed and correctly configured on agent's virtual desktops (hosted on RCI's on-prem VDI farm and managed by Citrix Cloud) - **TBC**.

entre Replatform

PIN: The customer's PIN is not displayed on the TSYS GUI screens, eliminating the risk of capturing PINs in agent screen recordings.

PAN: The PAN is displayed in the TSYS GUI and may be captured in agent screen recordings. Similar to audio recordings, there is a strong business requirement to retain these recordings containing PANs for a specific period (**TBC**). Compliance measures for these recording include:

- Secure encryption at rest.
- Restricting access to authorized personnel via Role-Based Access Controls (RBAC) to safeguard sensitive information.

Note: Agent screen recordings are stored in a dedicated S3 bucket created in the *CDE AWS account*. Amazon Connect instance (created and running in *RB Default AWS Account (non-PCI)*) is configured to send the recordings to this S3 bucket.

◦ Contact Trace Records (CTR) and Agent Events (AE) Data

CTR data includes metadata about customer interactions, such as timestamps, agent IDs, call duration, and call disposition. By design, it generally does not include sensitive customer data, such as PAN or PIN, unless explicitly misconfigured to log such details. Since our workflows do not pass PAN or PIN data to Amazon Connect or its related logs (refer to Sec 2.5.2 "Data Flow Diagrams"), there is no risk of such data sneaking into CTR or AE data.

AE data focuses on agent-related events, such as agent login, call hold/retrieve, or disconnect actions. It is highly unlikely to include PAN or PIN unless these values are explicitly passed or logged during the interaction flow.

Workflows and data handling processes are designed to prevent the capture or storage of sensitive data in Contact Trace Records (CTRs). Specifically:

- Ensure Lambda functions processing PAN/PIN do not log this data as part of debug information or custom attributes passed to Amazon Connect.
- Verify that contact flows are configured to avoid passing PAN or PIN as custom attributes (e.g., for IVR verification purposes).
- Regularly review Lambda function code to ensure sensitive data is neither logged nor inadvertently included in Amazon Connect attributes.
- Conduct periodic audits of Amazon Connect configurations and custom attributes in CTR/AE data to confirm no sensitive data is inadvertently captured.

Access to CTR and AE data is restricted to authorized personnel through Role-Based Access Controls (RBAC), ensuring that sensitive information remains secure. Additionally, any handling of CTR/AE data aligns with PCI DSS requirements, including logging and access restrictions.

Note: CTRs and AEs are stored in a dedicated S3 bucket created in the *RB Default AWS Account (non-PCI)*. This S3 bucket is encrypted at rest using a dedicated SSE-KMS key.

Encryption of Sensitive Account Data:

- Amazon Connect encrypts payloads containing sensitive account data (such as PANs and PINs) collected from a user within a contact/IVR flow using public-key cryptography.
- An AWS-managed asymmetric public-private key pair is generated by AWS KMS in the Cardholder Data Environment (CDE) AWS Account. The public key is used to encrypt the data in Amazon Connect, and the private key - always retained in AWS KMS - handles decryption operations.
- Since Amazon Connect does not natively integrate with AWS KMS for public key management, authorized administrators must export the public key from KMS and configure it manually in Amazon Connect. Rogers Bank's authorized personnel with the `kms:GetPublicKey` permission can use the `GetPublicKey` API or the AWS Management Console to export the public key in PEM format. Once exported, the public key is manually added to the Amazon Connect instance, where it is stored and used to encrypt payloads containing sensitive cardholder data (CHD).
- Safeguards must be put in place to prevent unauthorized modification of the public key after export, as tampering could compromise encryption integrity.
- The private key remains securely stored in AWS KMS within the CDE AWS Account and is never exported. All decryption operations are performed within KMS, aligning with PCI DSS requirements by confining sensitive cryptographic actions to a PCI-compliant environment.

Lambda Integration with CDE VPC:

Lambda functions are associated with the CDE VPC (and the same private subnet as the IC lambdas), ensuring that all traffic is routed within the private network, enhancing security and compliance.

Secure Retrieval of Secrets:

Lambda functions securely retrieve TSYS KeyID and KeySecret from AWS Secrets Manager at runtime using the AWS SDK. This approach avoids hardcoding sensitive credentials in the Lambda code or configurations. The functions communicate with TSYS using HTTPS secured with TLS 1.2 (or higher) to ensure end-to-end encryption of data in transit.

Data Containment:

No sensitive Cardholder Data (CHD) leaves the CDE environment to return to Amazon Connect contact flows, ensuring strict adherence to PCI DSS segmentation and data protection standards.

Auto Scaling and High Availability:

CDE VPC and Subnet Association:

Lambda functions are configured to run within CDE VPC. They are associated with an existing private subnet, ensuring secure routing and compliance with PCI DSS requirements.

Native Auto Scaling:

AWS Lambda functions leverage native auto-scaling capabilities managed by AWS. The number of concurrent Lambda executions automatically scales (within the defined account concurrency limits) based on the demand generated by Amazon Connect, ensuring high availability and responsiveness even during peak usage periods.

Outbound Network Traffic:

Egress Traffic Handling:

Egress traffic from the Lambda function to TSYS first passes through the NAT Gateway, which forwards the encrypted request to the AWS Network Firewall. The Network Firewall then applies domain-based allow-listing before directing the traffic to the Internet Gateway for TSYS Open API calls. This setup ensures that only outbound connections to the TSYS domain are permitted, prevents unauthorized inbound traffic, and provides a secure, monitored path for sensitive data.

Managed Stateful Service:

NAT Gateway is a fully managed, stateful service designed to pass data through while performing real-time IP address translation. Operating at the network

entre Replatform

layer (Layer 3 of the OSI model), it provides high-performance and reliable IP translation while maintaining connection state during sessions to ensure proper routing of return traffic. AWS automatically provisions the NAT Gateway across multiple Availability Zones (AZs) for redundancy, ensuring resiliency and high availability.

Ephemeral Operations:

The NAT Gateway operates at the network layer, performing operations (e.g., IP translation) in real-time. These operations are ephemeral and occur in memory only, with no data written to disk or persistent storage.

Connection State Management:

Connection state information (e.g., source and destination IPs, ports) required for NAT translation is maintained temporarily in memory while the connection is active. This state information is automatically cleared when the session ends, ensuring no residual sensitive data remains in memory.

Encryption Integrity:

The NAT Gateway does not inspect, modify, or store data payloads, including Cardholder Data (CHD). It processes data in transit without storing or persisting it. Payloads remain end-to-end encrypted in transit via HTTPS with TLS 1.2 or higher, ensuring compliance with PCI DSS encryption requirements.

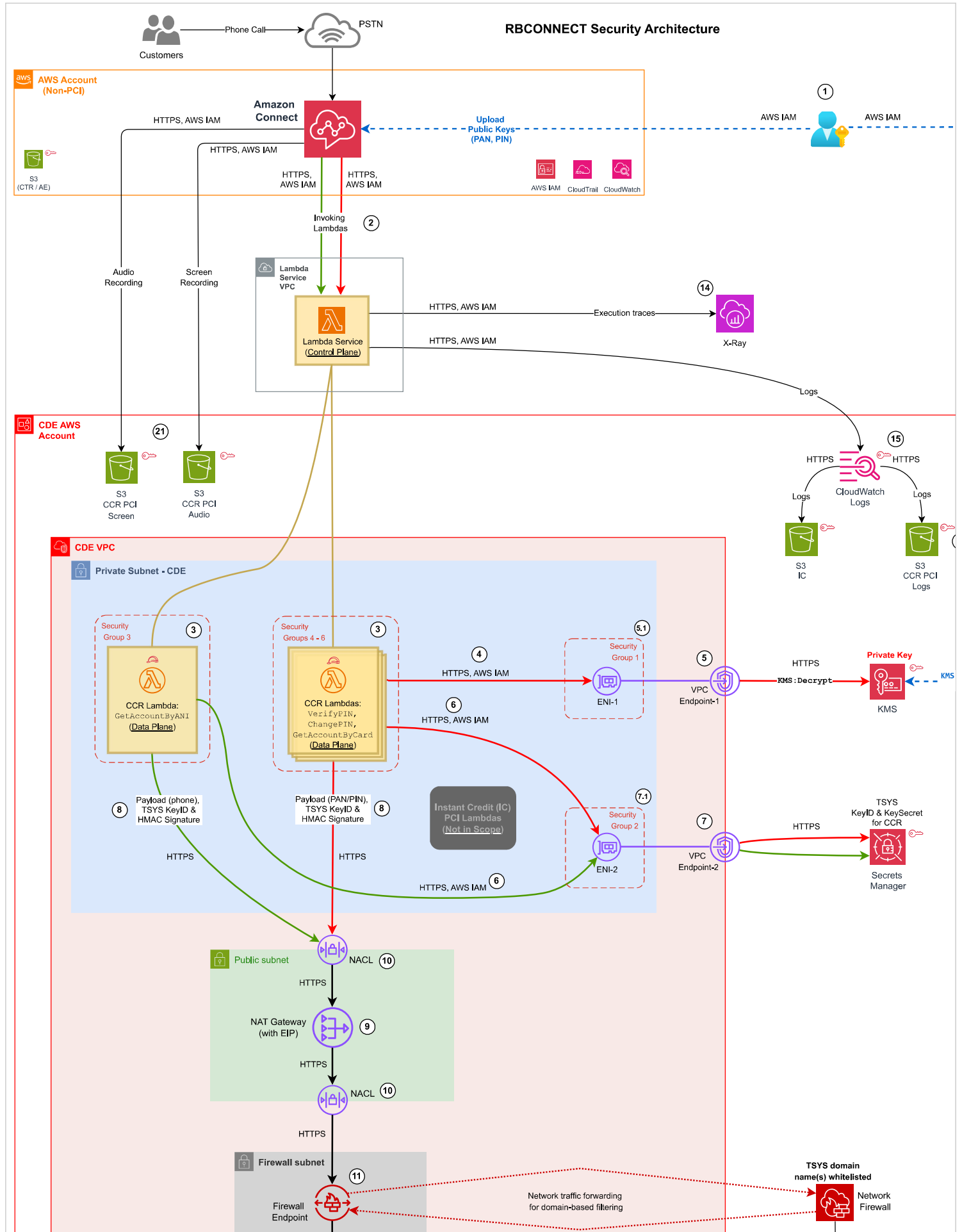
NAT Gateway:

The NAT Gateway does not inspect, modify, or store data payloads, including Cardholder Data (CHD). It processes encrypted traffic as a pass-through without decrypting it, ensuring no CHD is logged, stored, or processed persistently.

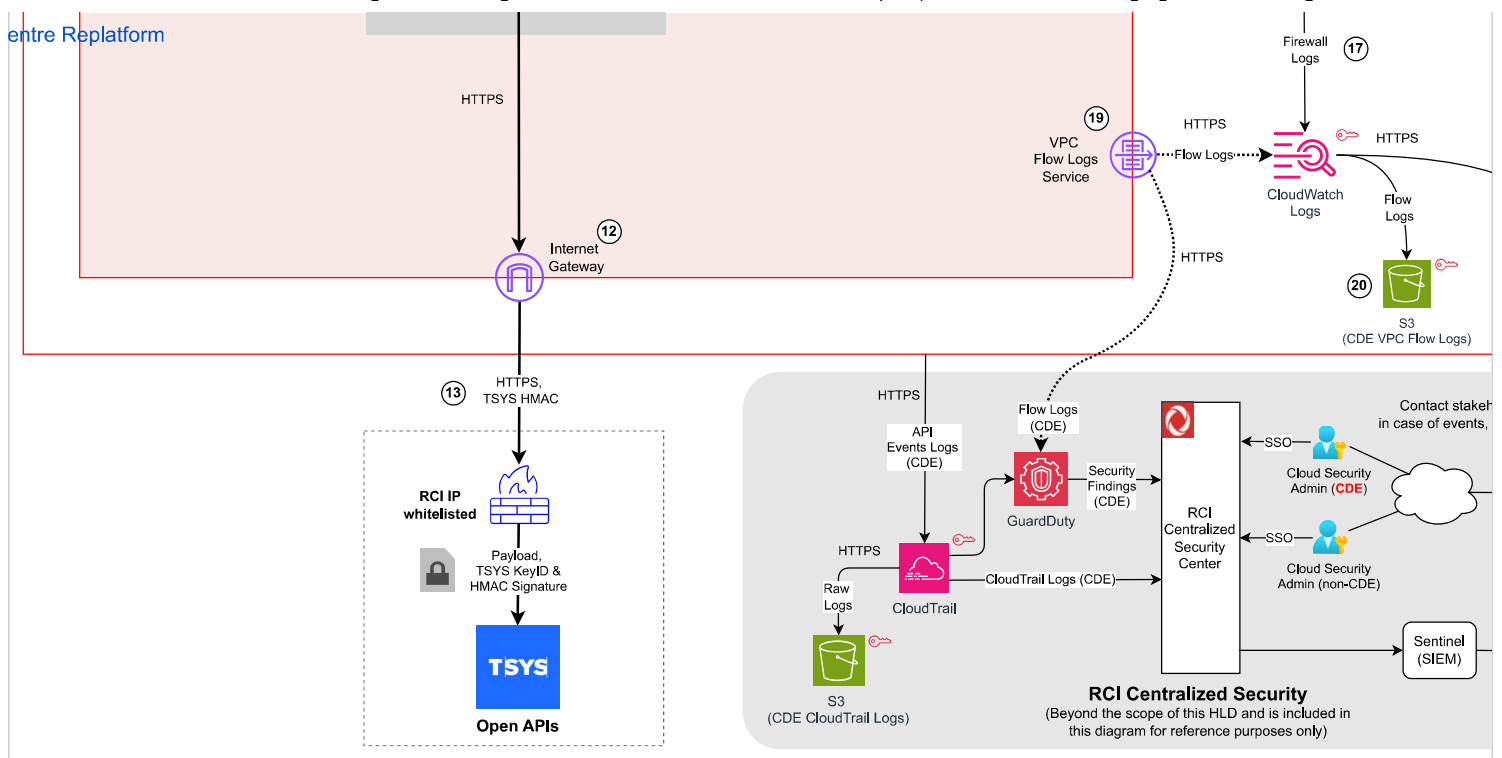
2.7.1 Security Solution View

NOTE: This is a logical representation. The Lambda functions data planes/runtime environments are technically part of the Lambda Service but access VPC resources through ENIs (AWS Elastic Network Interface) created within the VPC by the Lambda Service.

entre Replatform



entire Replatform



CCR PCI Lambda functions:

Lambda function	Use Case	Description	Lambda Input	Lambda Output	TSYS API
VerifyPin	Verify PIN	Decrypts the customer PIN and validates it by comparing it to the PIN fetched from TSYS	- Encrypted 4 digit PIN - accountID - customerID	isValid (True/False)	/issuing/digital/card/{accountID}/customer/{customerID}/pin/{ Digital Engagement TSYS Developers
ChangePin	Set/Update PIN	Send the request to TSYS to update the new PIN entered by customer.	Encrypted 4 digit PIN	Success status (True/False)	/issuing/digital/card/{accountID}/customer/{customerID}/setu Digital Engagement TSYS Developers
GetAccountByCard	Get Account Info by PAN	This function will get account details which includes card details by taking PAN as input	Encrypted 16 digit card number (PAN)	- accountID - customerID - AccountStatus - Customer's <u>registered</u> phone number	issuing/account/search Consumer Essentials TSYS Developers
GetAccountByANI	Get Account Info by ANI Match	This function will get account details which includes card details by taking incoming call's phone number (if it matches customer's phone	Incoming call's phone number	- Last 4 digits of PAN - accountID - customerID - AccountStatus - Customer's <u>registered</u> phone number	issuing/account/search Consumer Essentials TSYS Developers

entre Replatform					
		number) as input			

ID	INTERACTION / CONTROL	DETAILS
1	Public key → Amazon Connect	Rogers Bank's authorized personnel with the <code>kms:GetPublicKey</code> permission can use the the AWS Management Console or the <code>GetPublicKey</code> API to export the public keys (PAN Key -public and PIN Key - public) in PEM format. Once exported, the public keys are manually uploaded to Amazon Connect, where they are securely stored and used to encrypt payloads containing sensitive cardholder data (CHD). Amazon Connect supports uploading up to two keys at a time. This is a one-time configuration process and does not occur for every customer interaction with Amazon Connect. The public-private key pairs are periodically regenerated by AWS KMS as part of a key rotation policy. This ensures adherence to security best practices and ongoing compliance with PCI DSS requirements.
2	Lambda invocation	When a customer or an agent selects a PCI use case, the associated AWS Lambda function is invoked by Amazon Connect. The encrypted payload is passed to the Lambda function over HTTPS on AWS internal network. NOTE: For the Get Account Info by ANI use case, encryption of the payload (customer's phone number) at Amazon Connect is not required.
3	Security Groups - Lambda functions	Lambda functions configured to run within the CDE VPC utilize Elastic Network Interfaces (ENIs) that are created by the Lambdas and placed in the CDE private subnet. The ENIs are attached to security groups, which define inbound/outbound rules. These security groups are configured to allow outbound HTTPS (port 443) traffic to the NAT Gateway. The NAT Gateway then forwards the traffic to the AWS Network Firewall, where domain-based filtering of outbound traffic to TSYS is enforced. <i>(For simplicity, the Lambda ENIs are not depicted in this logical diagram).</i>
4	Lambda execution - Decrypt	The Lambda function's IAM execution role must have <code>kms:Decrypt</code> permission for the specific KMS key, ensuring that only authorized Lambda functions can request decryption of encrypted payloads. When the Lambda function receives an encrypted payload from Amazon Connect, it calls AWS KMS via the AWS SDK, invoking the <code>Decrypt</code> API. The encrypted payload is sent to KMS for decryption. The KMS key policy must allow the Lambda function's execution role to perform decryption. Importantly, the private key used for decryption is never exposed or retrieved by the Lambda function; it is securely stored and managed by AWS KMS. KMS handles the decryption process using the private key and returns the decrypted plaintext to the Lambda function. This ensures that the sensitive data is decrypted securely within KMS and is only accessible to authorized functions. By relying on AWS KMS for decryption, the Lambda function avoids handling sensitive cryptographic operations directly, adhering to best practices for security and compliance. Permissions are tightly managed using IAM policies and KMS key policies. All KMS key operations, including encryption, decryption, and key usage API events, will be logged in AWS CloudTrail

entre Replatform		
		(deployed in RCI's Centralized Security Account), ensuring traceability. AWS GuardDuty, also deployed in RCI's Centralized Security Account, will monitor and flag unauthorized attempts or anomalies related to KMS key usage. NOTE: The specific configuration of RCI's Centralized Security Account is beyond the scope of this HLD and is included in the diagram solely for reference. For more information, please refer to the HLD - Card Viewer (PCI), accessible via the link provided in the "Referenced Documents" section (Section 1.3).
5	VPC Endpoint - KMS	Lambda functions deployed in a VPC use an Interface VPC Endpoint-1 to securely access AWS KMS without traversing the public internet. To enforce least privilege, improve isolation, and enhance auditability, two distinct sets of AWS KMS encryption/decryption key pairs will be used in this solution: 1. One key pair (PAN Key) for the Lambda function handling the Get Account Info by PAN use case. 2. One shared key pair (PIN Key) for the Set/Update PIN and Verify PIN use cases. This separation aligns with the nature of the data handled by these use cases: ▪ Get Account Info by PAN use case: Deals with PAN. ▪ Set/Update PIN and Verify PIN use cases: Handle PIN-related data, which is inherently different. NOTE: For the Get Account Info by ANI use case, encryption of the payload (customer's phone number) at Amazon Connect is not required.
5.1	Security Group - ENI-1	This is a network-based control mechanism that manages inbound and outbound traffic to and from the elastic network interface (ENI) associated with the VPC endpoint for AWS KMS. The security group is attached to the ENI created by the VPC endpoint in the CDE private subnet and controls IP-level traffic between the CCR PCI Lambda functions and the VPC endpoint. This security group is configured to allow inbound HTTPS (port 443) traffic specifically from the security groups attached to the Lambda functions that require access to the KMS VPC endpoint. AWS automatically manages the routing of traffic from the VPC endpoint to the KMS service, and the default outbound rules of the security group (allowing all outbound traffic) are sufficient. This configuration ensures that only authorized Lambda functions within the specified security groups can securely communicate with the KMS endpoint.
6	Lambda execution - TSYS credentials	The Lambda function retrieves the TSYS KeyID and KeySecret from AWS Secrets Manager. It uses these credentials to generate the HMAC signature and construct the authentication header required for secure communication with TSYS APIs.
7	VPC Endpoint - Secrets Manager	Lambda functions deployed in a VPC use an Interface VPC Endpoint-2 to securely access AWS Secrets Manager, retrieve the TSYS KeyID and KeySecret, and use it for authentication with TSYS Open APIs.
7.1	Security Group - ENI-2	This is a network-based control mechanism that manages inbound and outbound traffic to and from the elastic network interface (ENI) associated with the VPC endpoint for AWS Secrets Manager. The security group is attached to the ENI created by the VPC endpoint in the CDE private subnet and controls IP-level traffic between the CCR PCI Lambda functions and the VPC endpoint. This security group is configured to allow inbound HTTPS (port 443) traffic specifically from the security groups attached to the Lambda functions that require access to the Secrets Manager VPC endpoint. AWS automatically manages the routing of traffic from the VPC endpoint to the Secrets service, and the default outbound rules of the security group (allowing all outbound traffic) are sufficient. This configuration ensures that only authorized

entre Replatform		
		Lambda functions within the specified security groups can securely communicate with the Secrets Manager endpoint.
8	Outbound Request to TSYS	Outbound traffic from the private subnet is first routed to the NAT Gateway, which forwards it to AWS Network Firewall for domain-based inspection and filtering. After passing the firewall, traffic proceeds via the Internet Gateway to TSYS over HTTPS (TLS 1.2 or higher). AWS Network Firewall applies domain-based filtering rules to ensure only requests to TSYS's domain are allowed, providing strict outbound control without requiring static IP allow-lists from TSYS.
9	Outbound traffic via AWS NAT Gateway	For outbound communication to TSYS, the private subnet's route table directs all 0.0.0.0/0 traffic to the NAT Gateway, which is deployed in a public subnet within the CDE VPC and has an attached Elastic IP (EIP). The NAT Gateway then forwards traffic to AWS Network Firewall for domain-based inspection and filtering. After passing through the firewall, traffic egresses to the Internet Gateway (IG) for TSYS Open API endpoints. AWS NAT Gateway is a stateful, AWS-managed service that automatically allows return/response traffic from TSYS - routing it back to the Lambda functions without additional inbound configuration. The NAT Gateway does not allow any unsolicited inbound connections.
10	Network Access Control Lists (NACLs)	NACLs (Network Access Control Lists) are stateless, requiring explicit rules to allow both outbound requests and inbound responses. Public Subnet NACL Configuration <u>Outbound Rule:</u> - Ensure the public subnet NACL allows outbound traffic from the NAT Gateway to the Network Firewall subnet (or firewall endpoint). This rule enables traffic to flow from internal resources through the firewall. <u>Inbound Rule:</u> - Allow return traffic from the Network Firewall subnet to the NAT Gateway on ephemeral ports. The ephemeral ports are dynamically allocated during the outbound connection and are used by the NAT Gateway for receiving responses. Note that the NAT Gateway itself is merely translating IPs, handling outbound traffic and return responses, and is not an application-level service "listening" on specific ports like 443. Instead, connections initiated by the lambdas use ephemeral ports (1024-65535) for outbound requests and inbound responses. Therefore, Do not open inbound port 443 on the public subnet NACL for the NAT Gateway, as it is unnecessary and could inadvertently expose the infrastructure. - Instead, configure the NACL to allow the entire ephemeral port range (1024-65535) for both outbound traffic and inbound responses. Private Subnet NACL Configuration - Use the default "allow-all" rules for the private subnet NACL. Traffic from the private subnet is routed through the NAT Gateway and subsequently filtered by the Network Firewall, providing centralized control over security and access policies. No Need for TSYS IPs in the NACL: Since we're relying on domain-based filtering in AWS Network Firewall, we don't have to manage large/dynamic IP ranges in the NACL. Instead, the NACL rules should simply permit traffic flows between the NAT Gateway and the Network Firewall subnets. The firewall will enforce fine-grained domain-based allow-lists. This configuration maintains a default deny-all posture at the NACL layer, except for explicitly required ports. AWS Network Firewall enforces domain-based filtering, providing an additional layer of security without relying on cumbersome IP-based configuration.

entre Replatform		
11	AWS Network Firewall	PCI DSS emphasizes controlling and monitoring both inbound and outbound traffic to protect the Cardholder Data Environment (CDE). In this design, Lambda functions reside in a private subnet within the CDE VPC. Outbound traffic from the Lambdas is routed to the NAT Gateway (in a public subnet), then proceeds to AWS Network Firewall for domain-based filtering and finally egresses via the Internet Gateway to TSYS. The Firewall Endpoint: - Acts as an interface in a dedicated Firewall subnet that forwards network traffic to AWS Network Firewall for domain-based filtering. - Ensure TSYS domain name(s) are whitelisted, so any Lambda traffic attempting to reach that domain is allowed, while all other domains are blocked. This Network Firewall: - Uses stateful Domain Name rules to restrict egress traffic exclusively to TSYS's domain on port 443, configured with FQDN match conditions. - Captures logs to provide visibility into network activity for continuous monitoring and auditing (<u>must be explicitly enabled</u>). Ensure logging of both Alert logs (to record traffic that matches alert rules) and Flow logs (to record the traffic flow (allowed/denied) through the firewall).
12	Internet Gateway	Egress endpoint for all outbound traffic from the CDE. Traffic passes from the private subnets → NAT Gateway → AWS Network Firewall → Internet Gateway → TSYS domain. All egress data is sent over HTTPS, secured with TLS 1.2 or higher.
13	Call to TSYS	The Internet-facing portion of the traffic flow begins after the outbound request passes through the NAT Gateway and AWS Network Firewall. From there, the request traverses the Internet Gateway to reach the TSYS domain. Data remains encrypted in transit using TLS 1.2 or higher, ensuring secure communication.
14	Execution traces	Lambda traces are securely transmitted to AWS X-Ray using HTTPS, as X-Ray relies on public network endpoints.
15	Lambda Logs	Lambda logs are captured in CloudWatch Logs and securely streamed over HTTPS. Each Lambda function will have unique logging identifiers and policies to ensure logs can be distinctly attributed to individual functions, enhancing traceability for debugging, troubleshooting, and auditing purposes.
16	S3 storage (Lambdas logs)	Lambda logs are archived in an S3 bucket dedicated to CCR PCI lambdas (GetAccountByCard, GetAccountByANI, /ChangePin, /VerifyPin). This S3 bucket is: - Encrypted at rest using an SSE-KMS key that is distinct from the key used for Lambda logs in the Instant Credit (IC) solution. - Organized into dedicated folder prefixes for each CCR PCI Lambda function (e.g., /GetAccountByCard, /GetAccountByANI, /ChangePin, /VerifyPin) for each Lambda function, ensuring clear separation and easier management of log data.
17	Firewall logs	Firewall logs are captured in CloudWatch Logs and securely streamed over HTTPS.
18	S3 storage (Firewall logs)	Firewall logs are archived in an S3 bucket dedicated to CCR CDE Firewall logs. This S3 bucket is encrypted at rest using a dedicated SSE-KMS key that is distinct from the key used for Lambda logs or the VPC Flow Logs.
19	VPC Flow Logs	VPC Flow Logs are captured in CloudWatch Logs and streamed securely over HTTPS.

entre Replatform		
20	S3 storage (VPC Flow logs)	VPC Flow Logs are archived in a dedicated S3 bucket and encrypted at rest using a dedicated SSE-KMS key for security.
21	S3 storage - CCR PCI Audio and Screen Recordings	Call audio and screen recordings are stored in separate S3 buckets. • Granular Access Control: Apply distinct access policies to audio and screen recordings, ensuring better control over who can access each type of data. • Customizable Retention Periods: Define different retention periods for audio and screen recordings to meet regulatory or business needs (TBD). • Cost Optimization: Utilize separate storage classes based on access patterns: ◦ Store frequently accessed screen recordings in S3 Standard (TBD). ◦ Archive audio recordings in S3 Glacier to reduce costs while ensuring compliance with long-term retention policies (TBD). • Linking Related Data: To correlate audio and screen recordings for the same interaction: ◦ Implement metadata tracking (e.g., store interaction IDs or timestamps as tags or in a database) (TBD). ◦ Use a consistent folder structure across buckets (e.g., <code>/<Year>/<Month>/<Day>/<InteractionID>/</code>). • Data Security: Encrypt each bucket at rest using dedicated SSE-KMS keys. This ensures that the data is independently secured, meeting PCI DSS standards and minimizing the risk of cross-bucket compromise.

2.7.2 Encryption - Data at Rest

- **Encryption of Lambda Environment Variables:**
Environment variables used by Lambda functions are encrypted at rest using AWS Key Management Service (KMS), ensuring secure storage of sensitive configuration data.
- **No Storage or Logging of Account Data:**
Account data is neither stored nor logged at any stage within the solution, adhering strictly to PCI DSS requirements.
- **Encryption of Logs and Storage:**
It is assumed that CloudWatch logs within the CDE are encrypted at rest. Similarly, any S3 storage utilized for logs or other data is configured to use server-side encryption (SSE) with AWS-managed keys.

2.7.3 Encryption – Data in Transit

- **Secure Communication with TSYS:**
All interactions between AWS Lambda functions and TSYS backend APIs are conducted over HTTPS, secured with TLS v1.2 or higher, ensuring data in transit is encrypted and protected.
- **Encryption of Account Data:**
Sensitive Account Data is encrypted within Amazon Connect using robust encryption mechanisms to safeguard information during processing.
- **Secure Lambda Invocations:**
All AWS Lambda invocations are conducted over HTTPS by default, ensuring secure communication between components within the AWS environment.

2.7.4 Identity and Access Management (IAM)

2.7.4.1 Authentication

Authentication with TSYS is implemented using TSYS HMAC, as outlined in the following documentation: [TSYS APIs authentication - Financial and Emerging Services - Rogers Wiki](#).

2.7.4.2 AWS Applications IAM authorization and access control details

Least privilege policies for IAM roles will be defined and reviewed during every change or, at a minimum, every 6 months. IAM, S3 bucket, and KMS key policies will be regularly reviewed and audited to ensure alignment with business needs and the security best practices.

The following table provides an overview of key IAM resources and control mechanism essential for secure and proper functioning of the solution in AWS. Each resource is designed to adhere to the principles of least privilege, isolation, and auditability. Resources will be configured specifically for each environment (DEV, STG, QA, PROD) to ensure consistency, compliance, and alignment with environment-specific requirements.

No.	Type	Resource	Description / Purpose	Key Permissions Scope
1	Resource-based Policy	KMS Key Policy – PAN Key	Attached directly to the KMS key used for PAN data.	- Grants <code>kms:Decrypt</code> to Lambda PAN role - Grants key mgmt perms (<code>kms:GetPublicKey</code>, <code>kms:DescribeKey</code>) to Key Administrator role
2	Resource-based Policy	KMS Key Policy – PIN Key	Attached directly to the KMS key used for PIN data.	- Grants <code>kms:Decrypt</code> to Lambda PIN role - Grants key mgmt perms (<code>kms:GetPublicKey</code>, <code>kms:DescribeKey</code>) to Key Administrator role
3	Resource-based Policy	Secrets Manager Secret Policy	Attached directly to the secret and grants or denies access directly on the resource the secret resource.	Restricts who can read/update a secret.
4	Resource-based Policy	S3 Bucket Policy	Attached to the AWS S3 (CCR PCI Audio) bucket that stores PCI call audio recordings and chat transcripts. Restricts read/write access to authorized principals only. Enforces server-side encryption.	• Allows <code>s3:PutObject</code>, <code>s3:GetObject</code> for trusted IAM • Denies public access.
5	Resource-based Policy	S3 Bucket Policy	Attached to the AWS S3 (CCR PCI Screens) bucket that stores PCI call audio recordings and chat transcripts. Restricts read/write access to authorized principals only. Enforces server-side encryption.	• Allows <code>s3:PutObject</code>, <code>s3:GetObject</code> for trusted IAM • Denies public access.
6	IAM Role	KMS Key Administrator Role	Manage KMS keys (create, rotate, delete, alias) and retrieve public keys.	- <code>kms:CreateKey</code>, <code>kms:GetPublicKey</code>, <code>kms:DescribeKey</code>, <code>kms:ListAliases</code>, <code>kms:UpdateAlias</code> - No data encryption/decryption
7	IAM Role	GetAccountByCard Lambda Execution Role	Least privilege and scoped permissions for: ▪ Accessing a specific private key in AWS KMS ▪ Retrieving specific credentials (TSYS KeyID & KeySecret) from AWS Secrets Manager ▪ Logging to CloudWatch ▪ Sending execution traces to AWS X-Ray	▪ <code>kms:Decrypt</code> for the specific key - PAN key ARN (required for payload decryption). ▪ <code>secretsmanager:GetSecretValue</code> on the specific TCR credentials' secret ARN. ▪ <code>logs:CreateLogGroup</code>, <code>logs:CreateLogStream</code>, & <code>logs:PutLogEvents</code> to enable logging to CloudWatch ▪ <code>xray:PutTraceSegments</code> and <code>xray:PutTelemetryRecords</code> to support distributed and execution tracing. ▪ Deny all other KMS keys.
8	IAM Role	GetAccountByANI Lambda Execution Role	Same as for GetAccountByCard	▪ <code>secretsmanager:GetSecretValue</code> for the specific s ▪ <code>logs:CreateLogGroup</code>, <code>logs:CreateLogStream</code>, & <code>logs:PutLogEvents</code> to enable logging ▪ <code>xray:PutTraceSegments</code> and <code>xray:PutTelemetryRecords</code> to support distributed and execution tracing.
9	IAM Role	VerifyPin Lambda Execution Role	Same as above	▪ <code>kms:Decrypt</code> for the specific key - PIN key ARN required for payload decryption. ▪ <code>secretsmanager:GetSecretValue</code> for the specific s ▪ <code>logs:CreateLogGroup</code>, <code>logs:CreateLogStream</code>, & <code>logs:PutLogEvents</code> to enable logging. ▪ <code>xray:PutTraceSegments</code> and <code>xray:PutTelemetryRecords</code> to support distributed and execution tracing.

No.	Replatform	Type	Resource	Description / Purpose	Key Permissions Scope
10		IAM Role	ChangePin Lambda Execution Role	Same as for VerifyPIN	Same as for VerifyPIN
11		IAM Service Role	Amazon Connect Service-Linked Role	Standard role for Connect.	No direct KMS permissions (key is manually uploaded)
12		IAM Role	Amazon Connect Admin/Developer Role	Configure Amazon Connect flows and upload public key.	- <code>connect : *</code> on the relevant Amazon Connect instance res - No KMS permissions needed (public key is already retrieved)
13		IAM Policy	VPC Policy	Used by Lambdas to be able to associate with CDE VPC.	To enforce the principle of least privilege: - Separate VPC policies remain in place to ensure Lambdas only have permissions to configure network interfaces in subnets. - Each Lambda function is granted only the permissions necessary to attach to the designated subnets, security groups, and relevant Interface VPC endpoints (VPC Endpoint-1 for AWS VPC Endpoint-2 for AWS Secrets Manager). Separate policies for each Lambda function will be created to facilitate permissioning.
14		Network-based control mechanism	Security Group 1	This is a network-based control mechanism that manages inbound and outbound traffic to and from the elastic network interface (ENI) associated with the VPC endpoint for AWS KMS . The security group is attached to the ENI created by the VPC endpoint in the CDE private subnet and controls IP-level traffic between the CCR PCI Lambda functions and the VPC endpoint.	This security group is configured to allow inbound HTTPS traffic specifically from the security groups attached to the Lambda functions that require access to the KMS VPC endpoint. AWS automatically manages the routing of traffic from the VPC to the KMS service, and the default outbound rules of the security group (allowing all outbound traffic) are sufficient. This configuration ensures that only authorized Lambda functions within the specified security groups can securely communicate with the KMS endpoint.
15		Network-based control mechanism	Security Group 2	This is a network-based control mechanism that manages inbound and outbound traffic to and from the elastic network interface (ENI) associated with the VPC endpoint for AWS Secrets Manager . The security group is attached to the ENI created by the VPC endpoint in the CDE private subnet and controls IP-level traffic between the CCR PCI Lambda functions and the VPC endpoint.	This security group is configured to allow inbound HTTPS traffic specifically from the security groups attached to the Lambda functions that require access to the Secrets Manager VPC endpoint. AWS automatically manages the routing of traffic from the VPC to the Secrets service, and the default outbound rules of the security group (allowing all outbound traffic) are sufficient. This configuration ensures that only authorized Lambda functions within the specified security groups can securely communicate with the Secrets endpoint.
16		Network-based control mechanism	Security Group 3	Attached to <code>GetAccountByANI</code> Lambda function to limit outbound access.	Allows outbound HTTPS (port 443) traffic only to the NAT Gateway (deployed in the public subnet in the CDE VPC), which subsequently routes traffic through the AWS Network Firewall. The AWS Network Firewall enforces domain-based filtering to restrict traffic destined to <code>*.tsys.com</code> . Strict egress rules in the security group + domain filtering in the Network Firewall ensures only authorized HTTP traffic to the domain is permitted.
17		Network-based control mechanism	Security Group 4	Attached to <code>VerifyPin</code> Lambda function to limit outbound access.	Same as above.
18		Network-based control mechanism	Security Group 5	Attached to <code>ChangePin</code> Lambda function to limit outbound access.	Same as above
19		Network-based control mechanism	Security Group 6	Attached to <code>GetAccountByCard</code> Lambda function to limit outbound access.	Same as above.
20		IAM Role	Terraform Module	Terraform Module Deployer Role for CDE account	This role's permissions will be scoped and restricted to only those required for Terraform deployments, such as resource creation, updates, without granting unnecessary read/write access to resources.
21		IAM role	Developer Role	Developer role for CDE account.	This role will ensure developers only have access to resources necessary for their tasks, avoiding direct access to production unless explicitly required. Separate development and production roles will be defined, with the developer role scoped to non-production environments by environment tags. Periodic reviews of developer permissions will be conducted to prevent privilege creep.

No.	Platform	Type	Resource	Description / Purpose	Key Permissions Scope
22	IAM Policy		Lambda Insights and X-Ray	This IAM policy is attached to the role(s) assumed by the CCR PCI Lambda functions at runtime and is intended for monitoring and troubleshooting, ensuring observability for compliance and operational needs. This integration provides visibility into metrics, logs, and end-to-end traces across the monitored Lambda functions and their dependencies.	Permissions are restricted to the minimum required for integ CCR PCI Lambda functions with CloudWatch and X-Ray. The policy grants access to CloudWatch for metrics and logs; Ray for both execution and distributed tracing, enabling com monitoring of the Lambda functions performance and interac - CloudWatch permissions include actions such as <code>PutMe</code> and <code>CreateLogStream</code> - X-Ray permissions include <code>PutTraceSegments</code> and <code>PutTelemetryRecords</code>.
23	IAM Service Role		CloudWatchLogsToS3Role	Allows CloudWatch to deliver logs to S3 (CCR).	<code>s3:PutObject</code> on the CloudWatch bucket <code>kms:GenerateDataKey</code>, <code>kms:Encrypt</code> on the relev KMS key used on the S3 (CCR) bucket. Trust Policy: Trust logs.delivery.amazonaws.com
24	IAM Service Role		Network Firewall Logging Role	Allows AWS Network Firewall to send logs to CloudWatch Logs and S3.	<code>logs:CreateLogStream</code>, <code>logs:PutLogEvents</code> on tl Trust Policy: Trust network-firewall.amazonaws.com
25	IAM Service Role		VPC Flow Logs Role	Consider custom role for VPC Flow Logs delivery (instead of the default service-linked role)!?	<code>logs:CreateLogStream</code>, <code>logs:PutLogEvents</code> on tl log group - KMS permissions for SSE-KMS. Trust Policy: Trust delivery.logs.amazonaws.com.
26	IAM Service Role		Lambda Logging Role	Allows AWS Lambda to write its own logs to CloudWatch Logs.	- Usually satisfied by the AWS-managed policy <code>AWSLambdaBasicExecutionRole</code>. - Minimum needed is <code>logs:CreateLogGroup</code>, <code>logs:CreateLogStream</code>, <code>logs:PutLogEvents</code>. Trust Policy: Trust lambda.amazonaws.com.
27	IAM Service Role		Amazon Connect Recording Role	Allows Amazon Connect to store call audio recordings and agent screen recordings in S3.	<code>s3:PutObject</code> on the Connect recordings buckets. <code>kms:GenerateDataKey</code>, <code>kms:Encrypt</code> for SSE-KMS Trust Policy: trust connect.amazonaws.com.
28	IAM-based Endpoint Policy		Interface VPC Endpoint-1 Policy	Attached to the VPC endpoint for KMS, further restricting which principals, which actions, which resources can use the VPC endpoint.	A JSON policy that specifies the ARNs of the lambda functio call <code>kms:Decrypt</code> via the VPC endpoint.
29	IAM-based Endpoint Policy		Interface VPC Endpoint-2 Policy	Attached to the VPC endpoint for Secrets Manager, further restricting which principals, which actions, which resources can use the VPC endpoint.	A JSON policy that specifies the ARNs of the lambda functio call <code>secretsmanager:GetSecretValue</code> via the VPC enc
30	IAM Service Role / IAM Policy		CloudTrail Service Role / S3 Bucket Policy	Allows CloudTrail to deliver logs to a dedicated S3 (CDE CloudTrail logs).	<code>s3:PutObject</code> on the CloudTrail bucket <code>kms:Encrypt</code> since SSE-KMS is used on the S3 bucke
31	IAM Service Role		GuardDuty Service Role	Allows GuardDuty to monitor and detect threats.	- Standard read-only log/event permissions

2.7.4.2.2 IT Dev roles, access control and Operations RACI - Aligned with **the HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link)

Members of Rogers Bank dev squads will have access to the different AWS accounts created for our AWS environments as follows:

[AWS Access and roles - Financial and Emerging Services - Rogers Wiki \(reqcentral.com\)](#)

The RACI for application support and operations can be reviewed in the below link:

[Rogers Bank Day 2 Support RACI - AWS - Rogers Wiki \(reqcentral.com\)](#)

2.7.5 Audit Logging and Monitoring

Refer to Sec 2.7.5 of the the **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link)

2.8 Other Architectural Characteristics

2.8.1 Availability, Scalability, Reliability and Maintainability

- Availability:**
The application is built using a **serverless architecture** leveraging AWS Lambda functions. Logs are stored in Amazon S3 for durability and accessibility. For this MVP phase, the solution's availability is limited to the **ca-central-1 AWS Region** and applies to all AWS services used within this region.
- Scalability:**
AWS Lambda automatically scales the number of execution environments in response to demand, up to the account's **concurrency limit**, which is set to **1,000 by default**.
This limit is shared among all applications running within the same Rogers Bank (RB) AWS account, including other services consuming the same quota. Additional scalability considerations depend on AWS service quotas and may require adjustments as usage increases.
- Reliability:**
The solution leverages AWS serverless services (such as Lambda, Amazon S3) to ensure high availability and recovery from potential service failures. AWS's inherent redundancy and fault tolerance further enhance reliability.
- Maintainability:**

The serverless architecture simplifies infrastructure management, especially for compute-intensive and event-driven applications, as the tools become increasingly accessible and cost-effective.
The foundation of this architecture relies on **stateless functions**, which may introduce maintainability challenges due to their transient nature and lack of persistent state.
To ensure robust maintainability:
 - The environment will be deployed and managed following RCI/RB best practices.
 - The codebase will reside under version control in Rogers' enterprise **GitHub**.
 - RCI DevOps pipeline templates (**ADO**) will be utilized, enforcing code quality and vulnerability scanning via tools like **SonarQube**.

AWS Lambda Development & Deployment (CI/CD pipeline)

1) CI/CD Pipeline:

- Code Signing with AWS Signer:**
All Lambda functions will be signed using **AWS Signer** with Rogers-specified keys. **Code signing** ensures that only trusted code runs in our Lambda functions. When enabled, Lambda verifies every code deployment to ensure the package is signed by a trusted source before allowing execution.
- Vulnerability Scanning:**
As part of the CI/CD pipeline, Lambda function code will be inspected for vulnerabilities using a **vulnerability database**. This includes:
 - Scrutinizing Lambda package dependencies for known vulnerabilities using appropriate tools.
 - Ensuring that any identified vulnerabilities are addressed before deployment.

2) Code Development:

- Runtime Environment:**
All Lambda functions will use **Node.js 22** as the runtime environment.
- Dependency Management:**
 - Dependencies listed in `package.json` must be pinned to exact versions that are approved and tested.
 - This ensures consistent and secure builds across environments.
- Retry Logic:**
Retry logic will be defined as part of the Low-Level Design (LLD). The application architecture should also allow flexibility to implement an overall retry mechanism if needed.
- Request Validation:**
All Lambda functions must validate incoming request parameters to ensure data integrity and security.
- Secure Logging:**
Lambda functions **must not log any PCI or PII** data to maintain PCI compliance and protect sensitive information.
- Code Linting:**
A code linter must be set up for the Lambda project, and no warnings should be reported during development and deployment.

2.8.2 Disaster Recovery

Yes

Component	Details
CDE	As per CDE Design
Amazon Connect	As per RBCONNECT Non-PCI HLD

2.8.3 Response Time

The solution aims to minimize IVR voice response times, ensuring that the duration from the user's input to the system's response does **not exceed 3 seconds**.

entre Replatform

2.8.4 Industry Compliance

All use cases outlined in this document are designed to comply with PCI DSS v1.4 standards. This HLD details how the in-scope use cases are implemented within the CDE VPC, ensuring alignment with PCI compliance requirements.

2.8.5 Volumetric & Service Level Agreement - High Level Impact Analysis

Volumetric & Service Level Agreement - High Level Impact Analysis

<<Discuss how solution addresses peak / average transaction requirements, maximum concurrent transactions and response time requirements. For each SLA and/or Business Metric, document what will this solution will deliver at launch and the life of the solution. i.e. The solution will deliver average hourly throughput of XXX with a maximum hard limit of XXX. Solution covers 2 years of BAU growth of 10% per month>>

No	System/Application	Service and/or business process (batch, online, or web)	Volume		Concurrent Users
			Average Daily Volume	Peak Hourly Volume	Peak Concurrent Users
1991	RBConnect	Cloud Contact Centre Platform (MVP Phase)	6942	1278	766

NOTE:

Given the data indicating a peak load of 766 concurrent users, the default AWS account concurrency limit of 1,000 should be sufficient to handle the expected workload. However, to mitigate cold start delays and improve performance, **provisioned concurrency** will be enabled to keep these Lambda functions warm, reducing cold start delays and ensuring consistent performance. It's been decided to start with 50 concurrent lambdas and fine-tune based on real-time as needed.

Similarly, AWS KMS has a throttling limit for 1,000 calls/sec for an account. As per the currently expected volume it is deemed to be sufficient. However, any additional use cases or increase in volume must consider this limit.

Cost** with and without provisioned concurrency for Lambdas with 3 sec duration and 512MB memory handling 800 request / sec (Canada region)

Normal w/o any warming function (complex)	provisioned concurrency=800
466 USD/month	615 USD/month

** This represents the worst-case scenario, with potential opportunities for optimization as more accurate data becomes available.

2.8.6 Enterprise Application Monitoring

The app classification is: **Important and non-prod before Q2-2025**. Application Monitoring and day 2 operations in general will be responsibility of Rogers Bank dedicated resources via CloudWatch (Alerts, dashboards, etc).

N/A

Technical Solution

List all the impacted applications and repeat the section 3.1 and it's subsections to cover the end-to-end solution for all impacted applications. This section will be completed by application owners for their respective applications.

3.0 Technical Solution Overview

The summary of the solution's architecture is as follows:

This project leverages the CDE environment created in the CDE AWS account (discussed in **HLD Card Viewer (PCI)** - refer to the "Referenced Documents" section in Sec 1.3 for the link) to execute PCI use cases. No PCI data is returned from the CDE AWS account to the CCR (RBCONNECT) non-PCI account, as this separation is enforced through strict security controls and the abstraction provided by AWS Lambda Service.

CCR RBCONNECT non-PCI use cases are described in the **HLD for CCR MVP (Non-PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link).

New/Modified/Decommissioned Interfaces - N/A

3.3 Application 1

RBCONNECT

3.3.1 Application Overview:

See Section 2.

3.3.2 Application architecture/design

N/A

3.3.3 Application Security Specifications

See section 2.7 Security Architecture

3.5 Infrastructure Solution

<< This section only needs to be produced if solution is implementing any new technology application / platform or solution require any infrastructure changes. It describes the platform configurations for the solution. >>

Refer to Sec. 2.8.1

3.5.2 High Level Technical Solution

Refer to the Solution Architecture section (For logical diagrams).

3.5.2.1 Key Concepts

Refer to Sec. 1.3

3.5.2.2 Environments

DEV, STG, QA, PROD - Same as in Sec 3.5.2.2 of the **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link)

3.5.2.3 Locations

Same as in Sec 3.5.2.3 of the **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link)

3.5.2.4 Network Security Zones

Same as in Sec 3.5.2.4 of the **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link)

3.5.2.5 Availability

Target availability SLA criteria met based on app Classification (**Critical**). [Application and Service Classification Description - Cloud Architecture - Rogers Wiki \(reqcentral.com\)](#)

Use case	Classification	Components	Estimated Compound SLA	Target Uptime SLA
Get Account Info by PAN, Verify PIN, Set/Update PIN	Critical	Amazon Connect, Lambda, KMS, Secret Manager, TSYS	0.9999 x 0.9995 x 0.99999 x 0.9999 x 0.9999 =0.9992	0.995
Get Account Info by ANI	Critical	Amazon Connect, Lambda, Secret Manager, TSYS	0.9999 x 0.9995 x 0.9999 x 0.9999 =0.9992	0.995

No	Application	Availability	Scalability	Maintainability
1	S3 Standard (TBC)	99.99%	§ provides infinitely scalable storage § 3,500 write request per second § 5,500 read request per second Write 1 file per day	AWS managed the physical infrastructure the OS and runtime
2	Lambda	99.95%	Auto scaling turned on	AWS managed the physical infrastructure the OS and runtime

3	Reqs	99.999%	default value is 10,000 for customer managed keys we are using it for 1 key	AWS managed the physical infrastructure the OS and runtime
4	Secrets Manager	99.99%	Quota for secrets is 500,000 Used for TSYS KeyID and KeySecret	AWS managed the physical infrastructure, the OS and runtime
5	AWS Connect	99.99%	AWS Connect can automatically scale to handle increased call volumes, allowing businesses to meet demand without manual intervention.	Regular updates and improvements are automatically applied, ensuring you always have access to the latest features and security enhancements without manual intervention.
6	CloudWatch	99.9%		AWS Managed
7	TSYS	99.99%		TSYS Managed

<< Include uptime window, maintenance window, overall infra availability requirements, High Availability, failure management. >>

3.5.2.6 Recoverability

<< Document Backup and Recovery policy (standard vs custom), need for Disaster Recovery, RTO (Recovery Time Objective), RPO (Recovery Point Objective), MTTR (Mean Time To Repair). >>

The Cardholder Data Environment (CDE) is planned to be deployed across multiple Availability Zones (AZs) to enhance availability and fault tolerance.

- The Lambda functions associated with the targeted private subnets will also be deployed across multiple AZs, ensuring high availability and resilience.
- Amazon S3, being region-specific, will be implemented with versioning enabled to protect data integrity. Additionally, lifecycle policies will be configured to transition data to S3 Glacier for cost-effective long-term storage.
- The code and CI/CD pipeline will follow existing Rogers practices to maintain consistency and compliance with organizational standards.

3.5.2.7 Capacity Management

<<All new applications require a Capacity Plan with identified KPIs and the ability to publish capacity status reports. The process and requirement for the reports will depend on the application or service criticality. More information around these report requirements can be found on the IT Capacity SharePoint. >>

The solution employs AWS Lambda with provisioned concurrency initially set to 50, based on estimated traffic. This configuration should be actively monitored to assess for throttling or underutilization. Alongside standard KPIs such as memory usage and CPU utilization, it is recommended to monitor throttling metrics and exception rates (e.g., *Throttles* and *ProvisionedConcurrencySpilloverInvocations*) to ensure optimal scaling and performance.

3.6 Infrastructure Design

3.6.1 Current State

CDE AWS account and CDE VPC are already available. Refer to the **HLD - Card Viewer (PCI)** (refer to the "Referenced Documents" section in Sec 1.3 for the link)

3.6.2 Next State

N/A

4.0 Approvals

Artifact Submission and Sign-off

Important Note: This artifact must be submitted to stakeholder approval via a Jira HLD ticket and not via email (See How to Create an HLD Artifact ticket for details). Embedded approval emails are not acceptable anymore. The requirements below would only apply in the exceptional case that Jira is not available, and approval of this artifact cannot wait for Jira to be back online. *PMO CoE reserves the right to reject this artifact* if it has been approved via email and there is enough grounds for PMO CoE to understand proper approval process via Jira could have been followed.

Regarding Sign-off Emails

- The sign-off must be received by email.
 - Not acceptable: conditional approval (e.g. of conditional approval is "I approve pending John Doe's approval of ABC").
- The sign-off email must include, at minimum, the project EPIC #, package # and version of the artifact. (e.g. 19EB0012 – Package 2 - ORD v2.1)
- The sign-offs must be embedded in the artifact
- For the complete list of standards, visit the PMO Knowledge Hub

Mandatory Check

entire Replatform

Operational Readiness Checklist (IT Scope) has been completed and shared with Operational Readiness Team:

- Yes
- No

Please note: above check is for capturing the status of OR checklist and selecting a "No" will not contribute to HLD rejection by PCO.

Function Area	Name	Project Roles	Sign-off	Sign-off Definitions
Rogers Bank Architecture	Jose Navarro	Enterprise Architect	v1.0 - 10 Dec 2024 v1.2 - 21 Jan 2025	
Cloud Architecture	Dwayne McGarty	Cloud Architect	v1.0 - 03 Dec 2024 v1.2 - 23 Jan 2025	
InfoSec/ICSU - Cyber Security Delivery and Classified Programs	Sam Karbassi	Network Security Architect / Adviser	v1.0 - 10 Dec 2024 v1.2 - 28 Jan 2025	
Data Governance	Sina Kashanizadeh	Senior Manager	v1.0 - 09 Dec 2024	As Data Governance, you approve that the E2E solution... [more]
Rogers Bank Delivery	Neil Campbell	Product Owner	v1.0 - 10 Dec 2024 v1.2 - 21 Jan 2025	

5.0 Appendix

5.1 List of Contributors

List all contributors that provided input to this document:

Function Area	Name	Project Role	Section they contributed to
Rogers Bank Delivery	Neil Campbell	Product Owner	1.1; 1.2; 1.4; 1.6; 1.7; 2.5.1
Rogers Bank Delivery	Ramesh Krishna	Project Manager	1.7
HCL	Abhishek Suman	HCL Consultant/Solution Architect	1.3; 1.4; 1.5; 1.7; 2.0; 2.4; 2.5 (version 1.0); 2.6; 2.7 (version 1.0); 2.8; 3.0; 3.3; 3.5; 3.6
HCL	Abhiraj Ghandi	HCL Consultant	1.4.3; 2.7.1 (Lambdas table for version 1.2)

entre Replatform	Function Area	Name	Project Role	Section they contributed to
	Rogers Bank Delivery	Robert Ascan	Solution Manager / Solution Architect	1.3; 1.4; 1.5; 1.7; 2.0; 2.4; 2.5; 2.6; 2.7; 2.8; 3.0; 3.3; 3.5; 3.6

5.2 Sign-Off Definitions

Highlights the accountabilities of each approver in this document:

Enterprise Data Governance

As Enterprise Data Governance, you confirm that the End-to-End solution:

- i. Complies to all relevant data and security policies and standards, including but not limited to the Data Governance Policy (ISEC4) and the Rogers Information Security Standard (RISS)
- ii. Was designed in accordance with relevant technology roadmap(s), data strategy, and data governance best practices
- iii. Does not deviate from approved access, consumption, and protection methods
- iv. Any data created or modified has been developed and deployed in a manner that is fit for use, purpose and ongoing integrity.

Solution Delivery Manager

As Solution Delivery Manager, you confirm that the End-to-End solution:

- i. Is sound and complete
- ii. Was designed in compliance with relevant technology roadmap(s), SDLC standards and best practices
- iii. Incorporates all the inputs provided by the impacted functional areas, including Production Support & Operations, and all key assumptions, risks and issues have been addressed except those listed in section 1.4
- iv. Meets the functional and non-functional requirements, as committed in the Requirements Matrix, and its delivery approach is feasible within the proposed Plan of Record and considering the listed constraints/dependencies/limitations

Platform Engineering Manager

As Platform Engineering Manager, you approve of the Infrastructure solution in this document, confirming:

- i. The infrastructure design is sound and complete
- ii. Compliance with relevant infrastructure roadmap(s), standards and best practices
- iii. The infrastructure design meets the technical requirements based on the solution architecture and application-level specifications
- iv. Delivery feasibility within the proposed Plan of Record, considering the listed constraints/dependencies/limitations

QA

As QA, you accept the Requirements Matrix and the HLD based on static testing confirming:

- i. The quality of the functional and non-functional requirements in the Requirements Matrix
- ii. The quality of the solution specifications in the HLD
- iii. The E2E solution specifications meet the IT response to the functional and non-functional requirements, as committed in the Requirements Matrix

IT Delivery Owner

As IT Delivery Owner, you commit to deliver the End-to-End solution:

- i. In alignment with the proposed Plan of Record (PoR)
- ii. As committed in the IT response to the functional and non-functional requirements in the Requirements Matrix
- iii. As designed in the HLD and considering the listed constraints/dependencies/limitations and key outstanding assumptions, risks and issues
- iv. In compliance with SDLC methodology, processes, standards, and best practices

Business Owner

As Business Owner, you accept the End-to-End solution for the Plan of Record (PoR):

- i. Based on the IT response to the functional and non-functional requirements, as committed in the Requirements Matrix
- ii. Based on the scope defined in the HLD Section 1, considering the listed constraints/dependencies/limitations and key outstanding assumptions, risks and issues

5.3 Document Abbreviations

List abbreviations and acronyms used in this document:

Abbreviation	Definition	Context (How/When it's used)

[entre Replatform](#)

✓ No one has confirmed reading this

[hld](#)